Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Малежик Юлии Михайловны
(фамилия, имя, отчество обучающегося)

Тема: Автоматизированная генерация мер и сценариев противодействия кибератакам: информационное и методическое обеспечение

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на _____ страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г.Остапенко)
(подпись) **(инициалы, фамилия)**

Руководитель _____ (Л.В. Паринова)
(подпись) **(инициалы, фамилия)**

Консультанты:
по _____ (_____)
(наименование раздела, подпись) **(инициалы, фамилия)**

по _____ (_____)
(наименование раздела, подпись) **(инициалы, фамилия)**

по _____ (_____)
(наименование раздела, подпись) **(инициалы, фамилия)**

по _____ (_____)
(наименование раздела, подпись) **(инициалы, фамилия)**

по _____ (_____)
(наименование раздела, подпись) **(инициалы, фамилия)**

Обучающийся _____ Ю.М. Малежик
(подпись) **(инициалы, фамилия)**

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности

Кафедра Систем информационной безопасности

Направление подготовки/специальность 10.05.03 Информационная безопасность автоматизированных систем
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ

ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Малежик Юлии Михайловне
фамилия· имя, отчество

1. Тема: Автоматизированная генерация мер и сценариев противодействия кибератакам: информационное и методическое обеспечение

ФГБОУ ВО «ВГТУ», ВГТУ
по заданию какой организации выполняется работа

приказ № 01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 01.07.2025

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Информационное обеспечение анализа киберугроз
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Раздел 2. Методическое обеспечение построения графовой модели для анализа киберугроз

Раздел 3. Методология автоматической генерации сценариев кибератак

Раздел 4. Методология автоматизированной генерации мер противодействия кибератакам

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
	Введение	11.03 – 11.05
	Информационное обеспечение анализа киберугроз	11.03 – 11.05
	Методическое обеспечение построения графовой модели для анализа киберугроз	23.05 – 31.05
	Методология автоматической генерации сценариев кибератак	01.06 – 12.06
	Методология автоматизированной генерации мер противодействия кибератакам	13.06 – 24.06
	Заключение	25.06 – 02.07

Руководитель _____
(подпись)

Дата выдачи задания 11.03.2025

Задание принял к исполнению 11.03.2025
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающейся Малежик Юлии Михайловны

Тема ВКР: Автоматизированная генерация мер и сценариев противодействия кибератакам: информационное и методическое обеспечение

Характеристика выпускной квалификационной работы

Актуальность исследования: в России в 2024 году зафиксировано более 1,8 миллиарда кибератак. В настоящее время одним из перспективных направлений в решении выявленных проблем ОИБ является применение графовых моделей анализа киберугроз. Учитывая опасность угроз, вызванных увеличением количества атак и ущерба, важным является разработка и автоматизация методов генерации мер и сценариев противодействия кибератакам в контексте анализа рисков.

Задачи, решаемые в ВКР: разработка структуры графовой базы данных, интегрированной с источниками актуальной информации, включая определение наименования узлов и типов связей между элементами графа; разработка методологии автоматической генерации сценариев кибератак для идентификации потенциальных цепочек атак с учетом влияния на доступность, целостность и конфиденциальность информации на основе данных из графовой модели; разработка методологии автоматизированной генерации мер противодействия кибератакам на основе анализа цепочек атак.

Структура ВКР: информационное обеспечение анализа киберугроз; методическое обеспечение построения графовой модели для анализа киберугроз; методология автоматической генерации сценариев кибератак; методология автоматизированной генерации мер противодействия кибератакам.

Краткая характеристика полученных результатов: разработана модель графовой базы данных, интегрирующая информацию из различных открытых источников (CAPEC, MITRE ATT&CK, CWE, CVE, NVD) в единую структуру, что обеспечивает анализ взаимосвязей между паттернами атак, техниками, слабостями и уязвимостями в рамках одной системы; создана методология построения цепочек атак на основе графовой модели, которая сокращает время анализа, минимизирует ошибки ручной обработки, учитывает вероятность успеха этапов атаки и потенциальный ущерб, позволяя ранжировать сценарии по уровню риска; предложена методология, охватывающая полный цикл анализа угроз — от выявления паттернов атак до разработки мер защиты, с акцентом на оперативное реагирование, что критично для противодействия сложным многоэтапным атакам.

Автор ВКР _____ Малежик Юлия Михайловна
(подпись)

СОДЕРЖАНИЕ

Введение 6
1 Информационное обеспечение анализа киберугроз 11
1.1 Анализ современных источников данных о киберугрозах 11
1.2 Методологические аспекты интеграции данных о киберугрозах 29
1.3 Преимущества графовой модели для систематизации данных 32
2 Методическое обеспечение построения графовой модели для анализа киберугроз 40
2.1 Формализация структуры графовой модели 40
2.2 Методика анализа рисков на основе графовой модели 44
2.3 Динамическое обновление данных в графовой модели 48
3 Методология автоматической генерации сценариев кибератак 50
3.1 Построение цепочек кибератак на основе графовой модели 50
3.2 Ранжирование сценариев кибератак по степени риска 52
3.3 Интеграция данных о мерах противодействия в графовую модель 53
4 Методология автоматизированной генерации мер противодействия кибератакам 55
4.1 Этапы жизненного цикла разработки мер противодействия 55
4.2 Методические основы автоматизации генерации мер противодействия 56
Заключение 60
Список литературы 62
Приложение А 72
Приложение Б 78

ВВЕДЕНИЕ

В современном мире киберугрозы становятся все более сложными и многоуровневыми, что требует разработки новых подходов к их анализу и противодействию [1-6]. В 2024 году киберпреступность продолжила активно атаковать как бизнес, так и обычных граждан. Статистика показывает тревожную тенденцию: количество прогосударственных APT-групп почти удвоилось, а число атак программ-вымогателей значительно возросло. Участились случаи утечек баз данных, а мощность DDoS-атак достигла новых максимумов [40].

Быстрая цифровизация приводит к лавинообразному росту киберугроз, делая кибербезопасность критическим фактором для устойчивого функционирования бизнеса и государства. В России в 2024 году зафиксировано более 1,8 миллиарда кибератак (данные «Лаборатории Касперского») [41].

Прогнозы на 2025 год предвещают дальнейшее усиление кибератак с применением ИИ, что приведет к созданию более эффективных фишинговых кампаний, совершенствованию дипфейков и повышению автоматизации взломов. Всё это увеличивает потребность в качественных решениях в сфере кибербезопасности.

В результате анализа тенденций развития кибератак становится очевидным, что традиционные методы обеспечения информационной безопасности, основанные на статических базах данных об уязвимостях, сигнатурном анализе и фиксированных правилах реагирования, оказываются все менее эффективными против современных киберугроз. Кроме того, рост продолжительности атак указывает на то, что многие системы не способны обнаруживать угрозу, пока она не нанесла ущерб системе, что указывает на то, что текущие подходы к обеспечению безопасности не способны адаптироваться к эволюции кибератак и вовремя обнаруживать и реагировать на угрозы.

Учитывая опасность угроз, вызванных увеличением количества атак и ущерба, важным является разработка и автоматизация методов генерации мер и сценариев противодействия кибератакам в контексте анализа рисков.

В данный момент одним из перспективных направлений в решении выявленных проблем обеспечения информационной безопасности является применение графовых моделей анализа киберугроз. Графы, в которых узлы представляют компоненты кибератак, а ребра - связи между ними, позволяют моделировать сложные сценарии атак. Но существующие подходы сильно ограничены в работе с динамично развивающимися угрозами информационной безопасности, а также с анализом различных абстрактных уровней кибератак.

В работе используется граф, который отражает все абстрактные уровни кибератаки, начиная от паттернов, описывающих сценарии кибератак, и заканчивая уязвимостями в конкретном информационном активе. Реализация такой модели будет обеспечивать гибкость за счет учета всего множества вариаций реализации атаки. Например, если обнаруживается новая уязвимость, граф динамически обновится, вычислив новые опасные сценарии кибератак и рекомендуя приоритетные меры противодействия по обнаружению, реагированию и ликвидации последствий возникших угроз.

Актуальность исследования обусловлена наличием ряда противоречий, выявленных в ходе анализа аналогов, между:

1) Сложностью современных кибератак, становящихся все более многоступенчатыми и целевыми, и ограниченностью традиционных методов анализа, которые не способны эффективно отслеживать сложные атаки.

2) Необходимостью быстрого реагирования на угрозы для эффективного противодействия кибератакам и временным лагом при анализе данных.

3) Универсальностью решений и спецификой защищаемых систем, что снижает эффективность мер защиты, так как универсальные рекомендации могут быть неприменимы в конкретных случаях.

Выше упомянутые противоречия демонстрируют, что существующие подходы к анализу угроз и разработке мер защиты нуждаются в совершенствовании, поэтому работа направлена на решение этих проблем за счет автоматизации процессов анализа и генерации мер защиты с использованием современных технологий и графовой модели анализа киберугроз.

Объектом исследования выступают процессы моделирования цепочек кибератак и разработки мер противодействия на основе графовой базы данных.

Предметом исследования являются методы и технологии генерации сценариев кибератак и мер противодействия на основе анализа взаимосвязей между паттернами атак (CAPEC), техниками (MITRE ATT&CK), слабостями (CWE) и уязвимостями (CVE).

Целью исследования является разработка методологии автоматизированной генерации сценариев кибератак и мер противодействия на основе интеграции данных из графовой базы знаний для повышения оперативности и эффективности защиты автоматизированных систем.

Задачи, решаемые в ходе исследования:

1) Разработка структуры графовой базы данных, интегрированной с источниками актуальной информации, включая определение наименования узлов и типов связей между элементами графа.

2) Разработка методологии автоматической генерации сценариев кибератак для идентификации потенциальных цепочек атак с учетом влияния на доступность, целостность и конфиденциальность информации на основе данных из графовой модели.

3) Разработка методологии автоматизированной генерации мер противодействия кибератакам на основе анализа цепочек атак.

На защиту выносятся следующие результаты:

1) Модель графовой базы данных для анализа киберугроз, где узлы представляют элементы угроз, а дуги - их взаимосвязи.

2) Разработанная методология автоматической генерации сценариев кибератак на основе данных из графовой модели.

3) Разработанная методология автоматизированной генерации мер противодействия кибератакам, основанная на интеграции данных из графовой базы данных (CAPEC, MITRE ATT&CK, CWE, CVE).

Результаты, выносимые на защиту, имеют следующую новизну:

1) Разработана модель графовой базы данных, интегрирующая информацию из различных открытых источников (CAPEC, MITRE ATT&CK, CWE, CVE, NVD) в единую структуру, что обеспечивает анализ взаимосвязей между паттернами атак, техниками, слабостями и уязвимостями в рамках одной системы.

2) Создана методология построения цепочек атак на основе графовой модели, которая сокращает время анализа, минимизирует ошибки ручной обработки, учитывает вероятность успеха этапов атаки и потенциальный ущерб, позволяя ранжировать сценарии по уровню риска.

3) Предложена методология, охватывающая полный цикл анализа угроз — от выявления паттернов атак до разработки мер защиты, с акцентом на оперативное реагирование, что критично для противодействия сложным многоэтапным атакам.

Теоретическая значимость результатов:

1) Разработанная модель демонстрирует применимость теории графов для анализа сложных взаимосвязей киберугроз, расширяя возможности использования графовых моделей в этой области. Формализованная структура интеграции данных из различных источников закладывает основу для дальнейших исследований в унификации данных о киберугрозах.

2) Созданная методология открывает перспективы для развития автоматизированных методов анализа угроз, формализует работу с графовыми моделями и подчеркивает важность системного подхода к оценке рисков.

3) Методология автоматической генерации мер противодействия создает основу для теоретического подхода к анализу угроз и разработке защитных мер, способствуя систематизации кибербезопасности. Она подчеркивает возможность оперативного создания мер защиты в реальном времени, расширяя представления об эффективности и скорости реагирования на киберугрозы.

Практическая ценность результатов дипломного проектирования состоит в следующем:

1) Предложенная модель упрощает анализ сложных взаимосвязей между элементами киберугроз, сокращая время на ручную обработку. Интеграция данных

из различных источников в единую графовую структуру повышает доступность и удобство использования информации в оперативной деятельности.

2) Созданная методология обеспечивает быстрое и автоматическое формирование сценариев атак на основе актуальных данных, что позволяет оперативно выявлять угрозы и снижать вероятность ошибок, связанных с ручным анализом. Автоматизация генерации сценариев освобождает специалистов от обработки больших объемов данных, повышая эффективность их работы.

3) Методология обеспечивает быстрое реагирование на угрозы за счет автоматизации процессов анализа и генерации мер защиты и позволяет разрабатывать конкретные меры противодействия, направленные на устранение выявленных угроз, что, в свою очередь, непосредственно повышает уровень киберустойчивости системы.

Ввиду сложности предметной области и разнообразия используемых терминов, их определения приведены в приложении Б (глоссарий), что позволяет читателю лучше ориентироваться в материале.

1 Информационное обеспечение анализа киберугроз

1.1 Анализ современных источников данных о киберугрозах

В современных системах анализа уязвимостей и управления рисками наблюдается значительный дефицит в области качественного представления и анализа взаимосвязей между уязвимостями, слабостями в системе и техниками. В уже существующих базах данных, таких как NVD (National Vulnerability Database) [42], данные о взаимосвязях между уязвимостями и их контекстом часто фрагментированы или отсутствуют. Эти базы данных фокусируются преимущественно на атрибутике отдельных уязвимостей (например, CVSS-оценки), но не обеспечивают достаточного уровня детализации для анализа зависимостей между уязвимостями, слабостями в системе и сценариями эксплуатации.

К тому же недавние планы по возможному прекращению финансирования NVD подчеркивают необходимость перехода к более гибким и автономным решениям, которые не зависят от конкретных источников данных [43].

Также важно отметить, что риск, связанный с уязвимостью, напрямую зависит от её взаимодействия с другими элементами системы. Соответственно, отсутствие или неполнота этих связей приводит к недооценке или переоценке рисков, что может повлечь за собой нерациональное распределение ресурсов на исправление уязвимостей.

Поэтому разработанная графовая база данных позволяет интегрировать данные из различных источников, включая CVE (Common Vulnerabilities and Exposures) [44], CWE (Common Weakness Enumeration) [45], MITRE ATT&CK [46,47], CAPEC (Common Attack Pattern Enumeration and Classification) [48], NVD (National Vulnerability Database) [42], CISA KEV (Cybersecurity&Infrastructure Security Agency Known Exploited Vulnerabilities) [49], EPSS (Exploit Prediction Scoring System) [50], CVSS (Common Vulnerability Scoring System) [51,52]. Это имеет большое преимущество, так как возможность добавления новых типов связей и атрибутов без изменения структуры базы данных обеспечивает высокую адаптивность к изменяющимся требованиям.

CAPEC (Common Attack Pattern Enumeration and Classification) - это словарь широко распространенных и хорошо известных атакующих методик и шаблонов поведения, которые могут использоваться злоумышленниками для эксплуатации общих типов ошибок в программном обеспечении (Common Weakness Enumeration, CWE). Он представляет собой структурированный набор информации, который предоставляет общую терминологию для описания и обсуждения атак, их вредоносные последствия, типичные методы защиты и связанные с ними уязвимости. CAPEC помогает ИБ-специалистам анализировать атаки и связанные с ними угрозы на более глубоком уровне, что важно для разработки эффективных мер безопасности и стратегий защиты. На данный момент база знаний CAPEC включает в себя описание более 500 паттернов атак [53].

CAPEC использует иерархический подход для классификации типов атак, который позволяет описывать атаки на разных уровнях абстракции и сложности. Эта структура помогает установить связи между различными атаками и упрощает идентификацию и анализ атакующих методов. Информация, предоставляемая для каждого шаблона атаки, включает подробное описание её контекста.

Важно, что база знаний CAPEC регулярно обновляется ИБ-специалистами, которые в ходе обновлений редактируют уже существующие паттерны атак и реже добавляют новые экземпляры. Об этом свидетельствует предоставленная авторами ресурса страница последних обновлений.

Несмотря на свою обширность, CAPEC не всегда предоставляет информацию о взаимосвязи различных атак, уязвимостей и техник, используемых злоумышленниками. Важным негативным аспектом является то, что CAPEC не предоставляет необходимую информацию о способах защиты от этих атак, для получения которой обычно требуется использование других ресурсов.

Ресурс CAPEC предоставляет исследователям информацию о слабостях программного обеспечения (CWE), связанных практически с каждым шаблоном атак. Это делает CWE важным элементом для формализации знаний о различных типах кибератак и уязвимостей. Однако в описаниях шаблонов атак CAPEC лишь

небольшая часть записей содержит явные ссылки на тактики и техники из MITRE ATT&CK, что ограничивает возможности для их интеграции.

Каждый шаблон атаки в CAPEC, согласно приведенной схеме, указанной на ресурсе с базой знаний, может содержать информацию, представленную в таблице 1 [53].

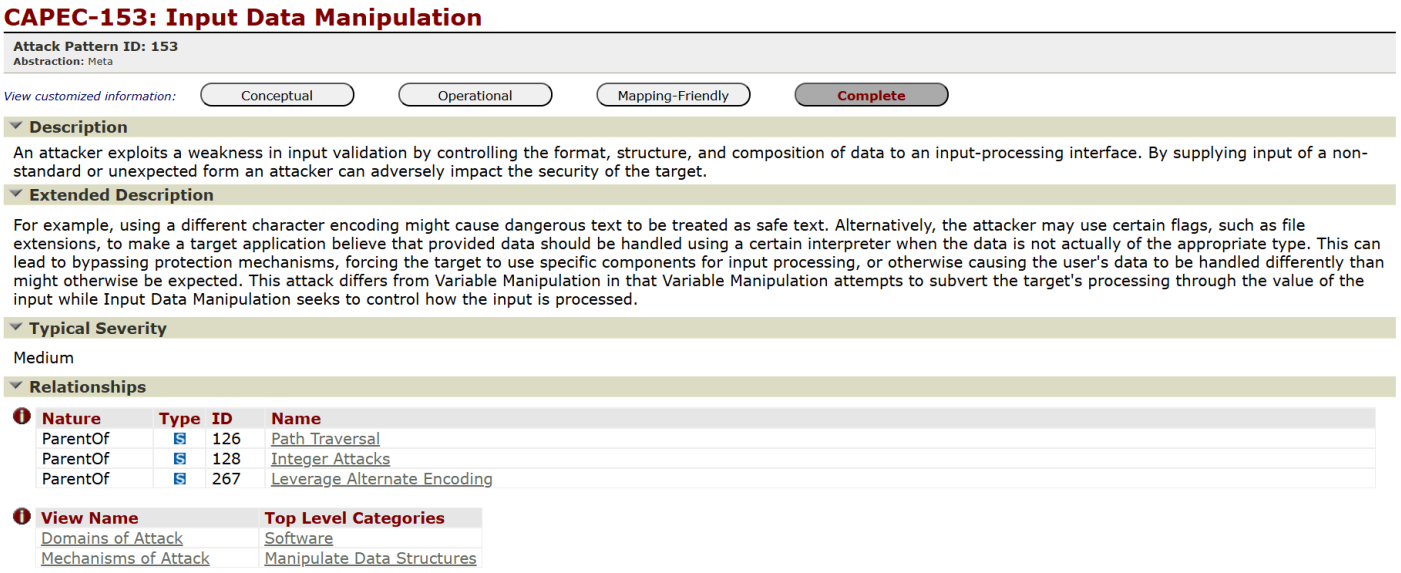
Таблица 1 - Наименования и краткое описание полей шаблона атаки CAPEC

Наименование	Краткое описание
ID и имя	Уникальный идентификатор
Описание	Подробное описание атаки, включая последовательность действий атакующего
Сводка	Краткое описание атаки, включая цель атаки и последовательность её шагов
Поток выполнения атаки	Перечень шагов, обычно выполняемых атакующим при осуществлении атаки
Альтернативные термины	Другие термины, используемые для идентификации шаблона атаки
Целевая атакуемая поверхность	Характеристики мест, с которыми атакующий взаимодействует в целевой системе
Предпосылки атаки	Условия, которые должны существовать для успеха атаки
Типичная серьезность	Отражает типичную серьезность атаки по шкале от очень низкой до очень высокой
Типичная вероятность эксплуатации	Вероятность успеха атаки с объяснениями и предположениями
Методы атаки	Перечень определенных векторов, идентифицирующих механизмы, используемые в атаке

Продолжение таблицы 1

Примеры-инстанции	Конкретные примеры или демонстрационные экземпляры атаки
Требуемые ресурсы	Ресурсы (вычислительные мощности, IP-адреса, инструменты и т.д.), необходимые атакующему для эффективного выполнения атаки
Техники зондирования	Методы, используемые для исследования потенциальной цели для определения уязвимости
Индикаторы-предупреждения об атаке	Активности, события, условия или поведение, которые могут указывать на то, что атака неминуема, в процессе или уже произошла
Техники обфускации	Методы, используемые для маскировки факта атаки
Мотивация и последствия атаки	Желаемые технические результаты, которые могут быть достигнуты с помощью этого шаблона атаки
Векторы внедрения, полезная нагрузка, зона активации, воздействие активации полезной нагрузки	Детали механизма и формат атаки на основе ввода данных
Связанные уязвимости и атаки	Специфические уязвимости или другие атаки, которые связаны с данным шаблоном атаки
Ключевые слова	Текстовые строки, используемые для маркировки и поиска данных в каталоге CAPEC
Ссылки	Ссылки на внешнюю документацию, которая была использована для разработки определения атаки или может быть полезной для дальнейшего изучения

Ниже рассмотрен шаблон атаки “Манипуляции с входными данными” (CAPEC-153: Input Data Manipulation) и проведен анализ, как различные свойства CAPEC полезны для анализа шаблонов кибератак в целом (рисунок 1).



CAPEC-153: Input Data Manipulation

Attack Pattern ID: 153
Abstraction: Meta

View customized information: Conceptual | Operational | Mapping-Friendly | **Complete**

Description

An attacker exploits a weakness in input validation by controlling the format, structure, and composition of data to an input-processing interface. By supplying input of a non-standard or unexpected form an attacker can adversely impact the security of the target.

Extended Description

For example, using a different character encoding might cause dangerous text to be treated as safe text. Alternatively, the attacker may use certain flags, such as file extensions, to make a target application believe that provided data should be handled using a certain interpreter when the data is not actually of the appropriate type. This can lead to bypassing protection mechanisms, forcing the target to use specific components for input processing, or otherwise causing the user's data to be handled differently than might otherwise be expected. This attack differs from Variable Manipulation in that Variable Manipulation attempts to subvert the target's processing through the value of the input while Input Data Manipulation seeks to control how the input is processed.

Typical Severity

Medium

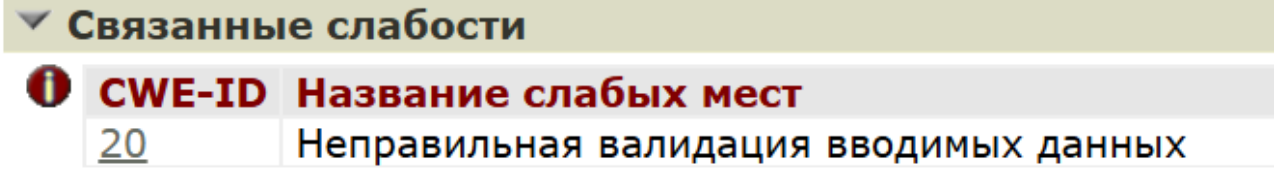
Relationships

Nature	Type	ID	Name
ParentOf	S	126	Path Traversal
ParentOf	S	128	Integer Attacks
ParentOf	S	267	Leverage Alternate Encoding

View Name	Top Level Categories
Domains of Attack	Software
Mechanisms of Attack	Manipulate Data Structures

Рисунок 1 - Пример записи шаблона атаки на сайте CAPEC

Каждый из образцов атак имеет свой числовой идентификатор. В данном примере это CAPEC-153. Номер не содержит никакой специальной информации и выдается образцам атак по мере внесения в базу знаний. У каждой записи CAPEC имеется заголовок и описание. Описание представляет собой краткое изложение того, о чем идет речь в шаблоне атаки. Почти у каждой записи CAPEC имеется поле со связанными с ним CWE. Пример приведен на рисунке 2.



Связанные слабости

CWE-ID	Название слабых мест
20	Неправильная валидация вводимых данных

Рисунок 2 - Пример поля с приведенным типом ошибки CWE на сайте CAPEC

Поле “Тип ошибки CWE” предоставляет исследователю информацию об ошибках программного обеспечения, которые могут привести к созданию уязвимости.

Common Weakness Enumeration (CWE) - поддерживаемая и развиваемая сообществом система классификации недостатков безопасности. CWE выступает в качестве общего языка, позволяющего описывать недостатки безопасности, включая сбои и ошибки при реализации программного или аппаратного обеспечения при проектировании, в архитектуре и т.д., которые могут сделать конечный продукт уязвимым к различного рода атакам. Основная цель CWE - предотвращать возникновение уязвимостей за счёт обучения специалистов способам исключения наиболее опасных ошибок, что в конечном счете позволяет избегать появления уязвимостей, которым подвержено программное и аппаратное обеспечение.

Важно отметить, что CWE активно поддерживается и обновляется сообществом, включая представителей ведущих производителей операционных систем и коммерческих инструментов обеспечения информационной безопасности.

Также CWE обеспечивает внешние отображения содержимого на связанные ресурсы, такие как база данных уязвимостей NVD NIST и CAPEC. Таким образом, появляется возможность связать описанные в базе знаний CAPEC шаблоны атак и уязвимости CVE базы данных NVD NIST.

Каждый тип ошибки программного обеспечения CWE согласно приведенной схеме, указанной на ресурсе, может содержать информацию, представленную в таблице 2 [53].

Таблица 2 - Наименование и краткое описание полей CWE

Название	Описание
CWE-ID	Уникальный числовой идентификатор, присвоенный каждой слабости в базе данных CWE
Name	Официальное название слабости, как оно представлено в CWE
Weakness Abstraction	Уровень абстракции слабости, указывающий на её общность или специфичность

Продолжение таблицы 2

Status	Текущее состояние слабости, например “Активный”, “Устаревший” или “Черновик”
Description	Краткое описание слабости, включая её природу и потенциальные последствия
Extended Description	Расширенное описание слабости с дополнительными деталями
Related Weaknesses	Список связанных слабостей, которые могут быть связаны или использоваться вместе
Weakness Ordinalities	Категоризация слабости по её порядковому номеру или типу
Applicable Platforms	Платформы, на которых слабость может проявляться
Background Details	Информация о фоне, которая может помочь в понимании слабости
Alternate Terms	Другие термины или названия, которые могут использоваться для обозначения слабости
Modes Of Introduction	Способы, которыми слабость может быть введена в систему или программное обеспечение
Exploitation Factors	Факторы, которые могут способствовать эксплуатации слабости, выраженные числовым значением
Likelihood of Exploit	Вероятность эксплуатации слабости, выраженная числовым значением
Common Consequences	Общие последствия, которые могут возникнуть в результате эксплуатации слабости
Detection Methods	Методы обнаружения слабости
Potential Mitigations	Потенциальные меры предосторожности или методы, которые могут быть применены для устранения или смягчения слабости
Observed Examples	Примеры, в которых наблюдалась данная слабость
Functional Areas	Функциональные области системы или программного обеспечения, которые могут быть затронуты слабостью
Affected Resources	Ресурсы, которые могут быть затронуты слабостью
Taxonomy Mappings	Ссылки на другие классификации или таксономии, где слабость также может быть найдена
Related Attack Patterns	Список связанных шаблонов атак, которые могут быть связаны или использоваться вместе со слабостью
Notes	Дополнительные заметки, комментарии или уточнения

Ниже рассмотрен пример ошибки CWE из выбранного ранее паттерна атаки CAPEC, а именно CWE-20 (рисунок 3).



Рисунок 3 - Пример карточки типа ошибки CWE

Очевидная взаимосвязь шаблонов атаки CAPEC и типов ошибки CWE приводит еще к одной взаимосвязи - уязвимостям CVE.

База знаний CVE (Common Vulnerabilities and Exposures) является одной из ключевых систем в области кибербезопасности, предоставляя стандартизированные идентификаторы для описания уязвимостей программного обеспечения. Common Vulnerabilities and Exposures - список известных уязвимостей и дефектов безопасности. Цель CVE - выявлять, описывать и каталогизировать информацию о публично раскрытых уязвимостях. Список создавался для унификации именования и регистрации обнаруженных дефектов безопасности. CVE позволяет специалистам по безопасности, инструментам обнаружения уязвимостей и базам данных уязвимостей получать и обмениваться информацией о конкретных дефектах. Благодаря этому они могут быть уверены, что имеется в виду одна и та же ИБ-проблема [53].

MITRE Corporation - американская некоммерческая организация, которая занимается исследованиями в области системной инженерии. Она поддерживает различные проекты, связанные с безопасностью, включая CVE и CWE.

CVE - это система, которая предоставляет стандартизированные идентификаторы для уязвимостей в программном и аппаратном обеспечении. Фактически эта система классифицирует различные типы уязвимостей.

Важно отметить актуальность использования базы знаний CVE. Она играет ключевую роль в индустрии информационной безопасности, предоставляя стандартизированный список уязвимостей. Перечень уязвимостей активно поддерживается корпорацией MITRE и финансируется Отделением национальной безопасности США, пополняется и обновляется ежедневно [14].

База CVE обеспечивает описание уязвимостей, назначение уникального идентификатора и ссылки на дополнительную информацию. На данный момент на информационном ресурсе размещено более двухсот тысяч уязвимостей, но стоит отметить, что не все уязвимости, зарегистрированные в CVE, остаются активными. Производители программного обеспечения регулярно выпускают патчи и обновления для исправления уязвимостей, после чего они перестают быть актуальными для эксплуатации.

Стоит заметить, что CVE тесно связана с другими ресурсами, такими как NVD, которая предоставляет анализ каждой уязвимости, опубликованной в списке CVE, и может включать оценки CVSS и информацию CWE. Такая интеграция обогащает базу CVE, делая её более полезной для анализа угроз и управления рисками. Таким образом, появляется возможность отследить смысловую последовательность “шаблон атаки CAPEC - тип ошибки программного обеспечения CWE - уязвимость CVE”.

Для расчёта данной метрики используется система EPSS (Exploit Prediction Scoring System), предназначенная для прогнозирования вероятности эксплуатации уязвимости в реальных условиях. О ней будет описано дальше.

Ниже будет рассмотрена карточка уязвимости CVE-2024-21309 в качестве примера для определения информационно-ценных полей (рисунок 4).

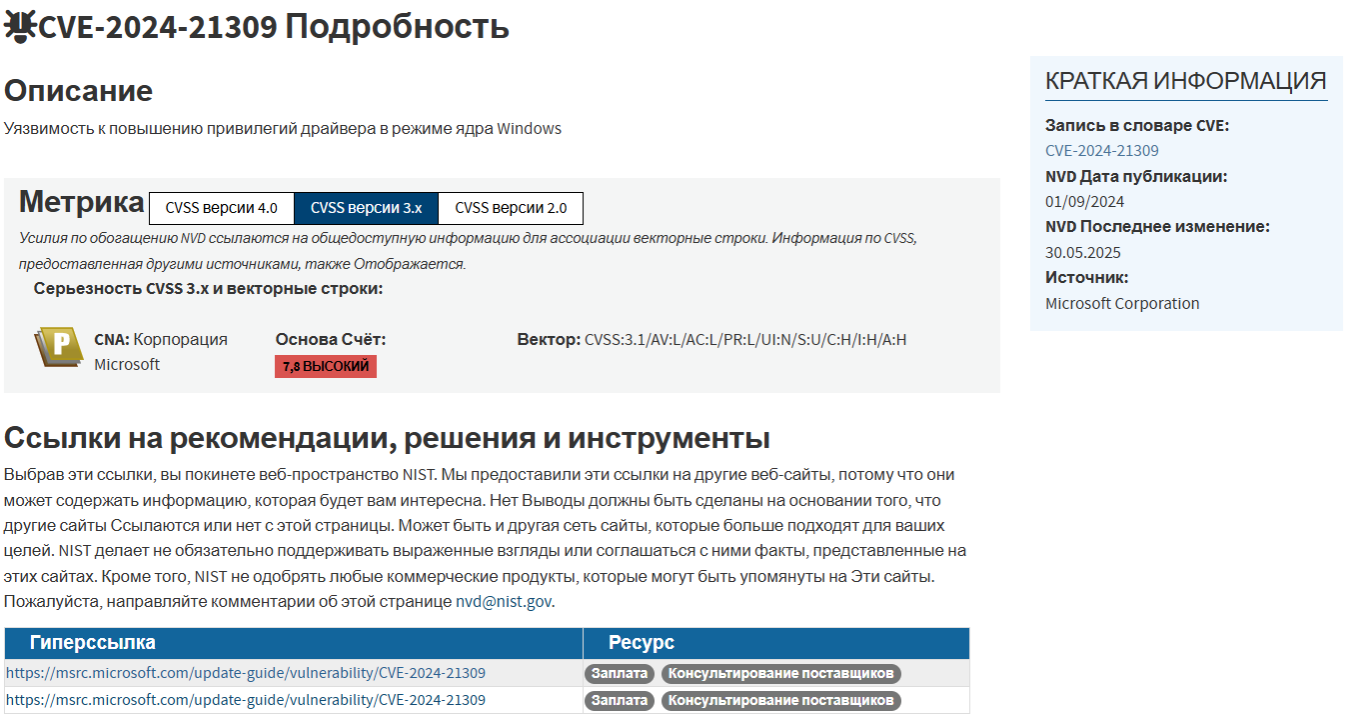


Рисунок 4 - Пример карточки CVE на сайте nvd.nist

Для каждой уязвимости CVE обязательными полями для заполнения являются описание, оценка её критичности, рассчитывающаяся на основе калькулятора CVSS, ссылки на рекомендации по её устранению и перечисление типов ошибок CWE, используемых при её реализации. В свою очередь, метрики оценки критичности являются важной информацией, позволяющей использовать их для риск-анализа (рисунок 5).

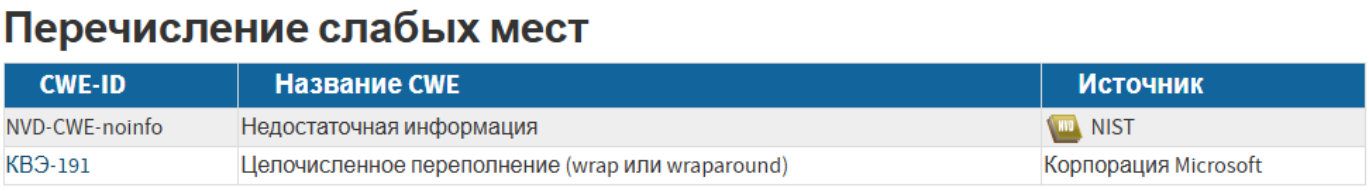


Рисунок 5 - Пример поля “Перечисление слабых мест” для уязвимости CVE

Проблема использования базы знаний заключается в том, что, несмотря на большое количество описанных уязвимостей, значительная их часть либо неактуальна из-за отсутствия подтвержденных случаев эксплуатации, либо связана с

устаревшим программным или программно-аппаратным обеспечением, которое практически не применяется в современных условиях.

Поэтому далее будет разобран следующий ресурс, основанный на использовании базы знаний CVE NIST.

CISA KEV (Known Exploited Vulnerabilities) Catalog является источником информации, поддерживаемым Агентством кибербезопасности и инфраструктурной безопасности США (CISA) и содержащим перечень уязвимостей, которые были активно эксплуатированы злоумышленниками. Этот каталог предназначен для использования организациями с целью приоритизации устранения уязвимостей, чтобы снизить вероятность компрометации известными угрозами.

Актуальность базы знаний заключается в том, что она содержит список CVE (уязвимости, которые уже используются в реальных атаках), дату добавления (когда уязвимость была добавлена в каталог) и требования к исправлению (рекомендации по устранению уязвимости) [54].

Цель CISA KEV - помочь организациям приоритизировать уязвимости для исправления, фокусируясь на тех, которые представляют наибольшую угрозу из-за их активной эксплуатации.

Также миссия CISA в области кибербезопасности заключается в защите и обеспечении безопасности киберпространства, возглавляя национальные усилия по стимулированию и обеспечению эффективной национальной киберзащиты, устойчивости национальных критически важных функций и надежной технологической экосистемы [55].

Ниже приведен пример карточки актуальной уязвимости CVE, которая уже используется в реальных атаках (рисунок 6).

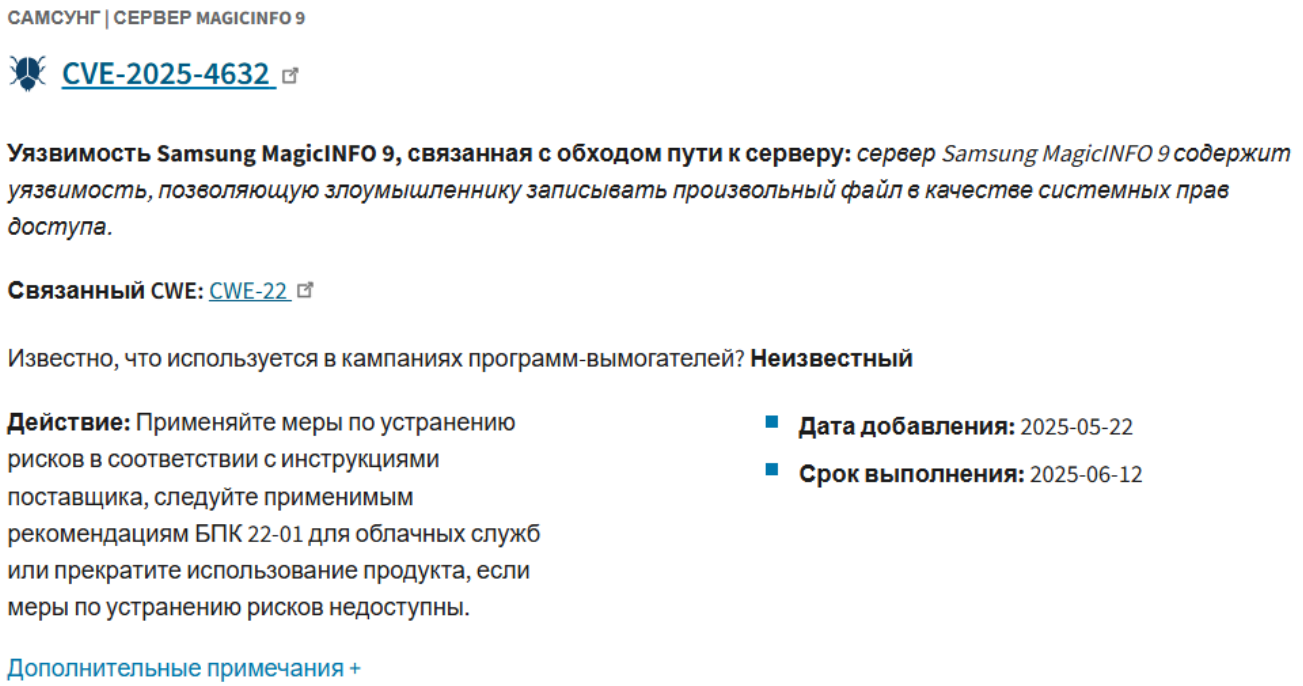


Рисунок 6 – Пример карточки CVE на сайте cisa.gov

Основная ценность этого инструмента заключается в концентрации на реальных рисках. То есть каталог содержит только те уязвимости, которые уже эксплуатируются злоумышленниками, это позволяет сосредоточиться на уязвимостях с высокой вероятностью атаки, а не на всех возможных CVE. В работе рассматривается порядка 200 тысяч уязвимостей (а именно, 201 386). Многие из них могут быть теоретическими или редко используемыми, поэтому благодаря данному каталогу можно приоритизировать критичные уязвимости, которые представляют наибольший риск.

Важно, что CISA KEV поддерживается государственным агенством США, то есть пользуется доверием в области кибербезопасности и все данные основаны на достоверных источниках, таких как отчеты об инцидентах, исследования эксплойтов, подтвержденные случаи эксплуатации. А это, в свою очередь, дает уверенность, что уязвимости KEV действительно представляют угрозу, а не являются гипотетическими рисками.

Как уже упоминалось, CISA KEV служит ключевым инструментом для выявления уязвимостей, которые уже были использованы злоумышленниками. Эти

сведения особенно ценны, поскольку помогают сосредоточить усилия на устранении уязвимостей, представляющих наибольшую угрозу.

Однако для более глубокого понимания способов их эксплуатации необходимо использовать базу знаний MITRE ATT&CK — общедоступный ресурс, описывающий тактики и техники, применяемые злоумышленниками для достижения своих целей.

В рамках графовой модели информация из CISA KEV связывается с техниками MITRE ATT&CK посредством взаимосвязей между уязвимостями (CVE) и архитектурными слабостями (CWE). Такой подход позволяет определить наиболее вероятные векторы атак и формировать приоритетные меры защиты.

MITRE ATT&CK включает в себя информацию по тактикам (tactics) и техникам (techniques). Всего в рамках MITRE ATT&CK описано 14 основных тактик (например, «Разведка» (Reconnaissance), «Разработка ресурсов» (Resource development), «Повышение привилегий» (Privilege Escalation) и др.). Также для каждой тактики описаны свои техники (например, для тактики «Разведка» описаны такие техники, как «Активное сканирование» (Active scanning), «Сбор информации о хосте жертвы» (Collecting information about the victim's host) и т.д.).

На рисунке 7 приведен пример тактики «Разведка» и её техники «Активное сканирование», которая, в свою очередь, включает в себя ещё 3 подтехники. Также можно заметить описание данной техники.

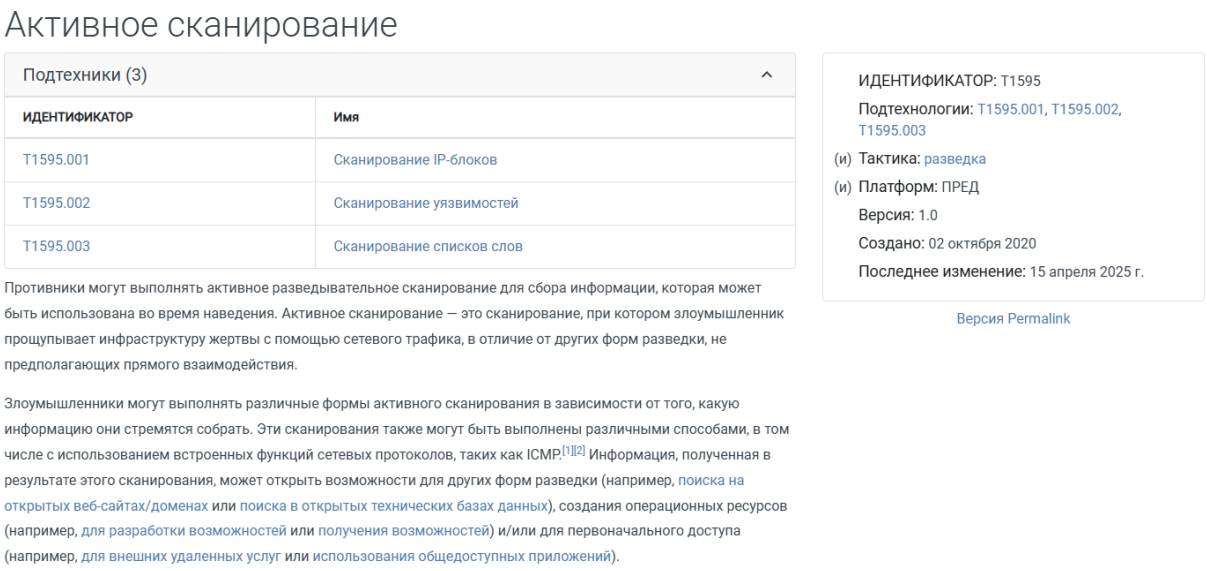
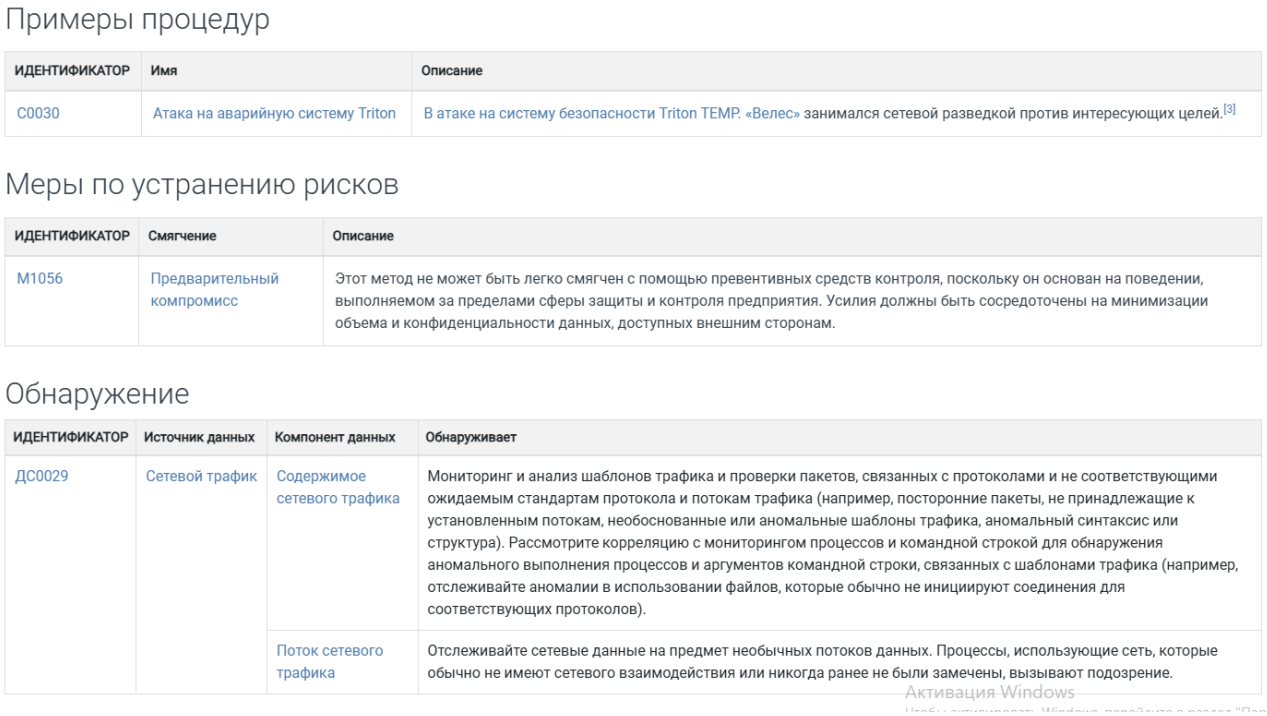


Рисунок 7 – Пример тактики и её техники на сайте attack.mitre

Для выше приведенной T1595 также можно ознакомиться с примерами процедур (конкретные примеры того, как злоумышленники реализуют каждую технику), с мерами по устранению рисков (рекомендации по предотвращению или минимизации последствий использования каждой техники) и разделом «обнаружение» (содержит информацию о том, как можно выявить использование каждой техники). Пример данной информации представлен на рисунке 8.



Примеры процедур

ИДЕНТИФИКАТОР	Имя	Описание
C0030	Атака на аварийную систему Triton	В атаке на систему безопасности Triton TEMP. «Велес» занимался сетевой разведкой против интересующих целей.[3]

Меры по устранению рисков

ИДЕНТИФИКАТОР	Смягчение	Описание
M1056	Предварительный компромисс	Этот метод не может быть легко смягчен с помощью превентивных средств контроля, поскольку он основан на поведении, выполняемом за пределами сферы защиты и контроля предприятия. Усилия должны быть сосредоточены на минимизации объема и конфиденциальности данных, доступных внешним сторонам.

Обнаружение

ИДЕНТИФИКАТОР	Источник данных	Компонент данных	Обнаруживает
ДС0029	Сетевой трафик	Содержимое сетевого трафика	Мониторинг и анализ шаблонов трафика и проверки пакетов, связанных с протоколами и не соответствующими ожидаемым стандартам протокола и потокам трафика (например, посторонние пакеты, не принадлежащие к установленным потокам, необоснованные или аномальные шаблоны трафика, аномальный синтаксис или структура). Рассмотрите корреляцию с мониторингом процессов и командной строкой для обнаружения аномального выполнения процессов и аргументов командной строки, связанных с шаблонами трафика (например, отслеживайте аномалии в использовании файлов, которые обычно не инициируют соединения для соответствующих протоколов).
		Поток сетевого трафика	Отслеживайте сетевые данные на предмет необычных потоков данных. Процессы, использующие сеть, которые обычно не имеют сетевого взаимодействия или никогда ранее не были замечены, вызывают подозрение.

Активация Windows

Рисунок 8 – Описание техники T1595 на сайте attack.mitre

Использование выше изученных баз данных в сочетании с калькуляторами, такими как CVSS [51,52] и EPSS [50], позволяет глубже понять природу угроз и адаптировать свои стратегии к требованиям текущей киберугрозы. Интеграция данных из баз и проведение расчетов в рамках риск-анализа, а также последующее выявление наиболее опасных сценариев кибератак, представляют собой ключевой элемент комплексной стратегии кибербезопасности. Это позволяет минимизировать возможные последствия атак и повысить устойчивость системы к киберугрозам.

CVSS (Common Vulnerability Scoring System) – это открытый стандарт, используемый для расчета количественных оценок уязвимости в безопасности компьютерной системы. Оценки рассчитываются по специальным формулам на основе нескольких метрик и приблизительно оценивают простоту внедрения

эксплойта и его влияние на компьютерную систему. Результатом расчета являются три числовые оценки (Base Score, Temporal Score и Environmental Score), каждая из которых может принимать значение от 0 до 10, где 0 означает, что уязвимость не представляет серьезной угрозы, а 10 означает, что уязвимость представляет чрезвычайно серьезную угрозу [56].

Версии CVSS 3.1 и CVSS 4.0 представляют структурированный подход к анализу уязвимостей, что делает их особенно полезными в контексте данной работы.

CVSS (Common Vulnerability Scoring System) версии 3.1 – это усовершенствованная версия CVSS 3.0, которая широко используется в индустрии. Она представляет выше упомянутые три числовые оценки или три группы метрик для оценки уязвимостей [42]:

1) Базовая метрика (Base Score) оценивает внутренние характеристики уязвимости (например, сложность эксплуатации, влияние на конфиденциальность, целостность и доступность).
2) Временная метрика (Temporal Score) учитывает временные факторы, такие как наличие публичных эксплойтов или исправлений.
3) Контекстная (экологическая) метрика (Environmental Score) учитывает специфику окружения (например, важность системы, где обнаружена уязвимость).

CVSS (Common Vulnerability Scoring System) версии 4.0 – это новая версия, выпущенная в 2023 году. Она состоит также из трех групп метрик: базовые, временные и экологические [56,57].

Базовые используются для оценки серьезности уязвимости без учета конкретных контекстов и условий. Они включают в себя:

1) Вектор атаки;
2) Сложность атаки;
3) Требуемые привилегии;
4) Влияние на конфиденциальность, целостность и доступность.

Временные метрики используются для оценки серьезности уязвимости с учетом времени, прошедшего с момента ее обнаружения или раскрытия и включают в себя:

1) Эксплуатируемость;
2) Уровень оповещения.

Экологические метрики дают оценку серьезности уязвимости с учетом конкретных контекстов или условий:

1) Влияние на безопасность;
2) Влияние на доступность;
3) Влияние на целостность.

Уровни рейтинга CVSS 4.0 считаются на основе значений базовых, временных и экологических метрик. Чем выше значения этих метрик, тем выше будет оценка CVSS и уровень рейтинга. Всего выделено 4 уровня:

1) Низкий (Low): 0.1-3.9;
2) Средний (Medium): 4.0-6.9;
3) Высокий (High): 7.0-8.9;
4) Критический (Critical): 9.0-10.0.

CVSS калькулятор пользуется большой популярностью, он лежит в основе многих калькуляторов (EPSS и др.) и широко применяется, так как он стандартизирован, универсален и его оценки позволяют сравнивать уязвимости между собой и определять приоритеты.

EPSS (Exploit Prediction Scoring System) – это ежедневная оценка вероятности эксплуатационной деятельности, наблюдаемой в течение следующих 30 дней. Созданный с нуля, он спроектирован так, чтобы максимально эффективно обрабатывать все доступные данные. Это работа на основе данных, в которой используется актуальная информация об угрозах из CVE и реальные данные об эксплойтах. Модель EPSS дает оценку вероятности от 0 до 1 (от 0 до 100%), где чем выше оценка, тем больше вероятность того, что уязвимость будет использована [58,59].

EPSS помогает специалистам по кибербезопасности приоритизировать усилия по устранению уязвимостей, фокусируясь на тех, которые с наибольшей вероятностью могут быть использованы злоумышленниками [60].

EPSS основывается на статистических моделях, которые используют данные об уязвимостях, связанных с ними событиях и факторах риска. Основное внимание уделяется байесовским моделям вероятности, анализа взаимосвязей между уязвимостями и данными о нападениях. Принцип работы включает [56]:

1) Сбор данных: EPSS анализирует множество параметров уязвимостей, таких как тип уязвимости, связанные CVE (Common Vulnerabilities and Exposures) коды, а также внешние данные – отчёты о случаях эксплуатации и активности угроз.
2) Обработка факторов риска: система использует факторы, связанные с эксплойтами, такие как наличие уязвимостей в открытых источниках, информация о патчах и данные об активности злоумышленников. Важными метриками также являются сложность эксплуатации и степень потенциального ущерба.

Моделирование и предсказание: EPSS оценивает вероятность того, что уязвимость будет использована в течение определенного времени (как правило, 30 дней), и выдает оценку на основе вероятностных моделей. В EPSS шкала измерения колеблется от 0 до 1.

Подытожив всё вышеизложенное, выведу в таблицы 3 и 4 используемые базы данных и калькуляторы атак и уязвимостей соответственно.

Таблица 3 – Используемые базы данных

Название	Описание	Собираемые данные
CAPEC (Common Attack Pattern Enumeration and Classification)	База данных, которая описывает типовые паттерны атак; фокусируется на высокоуровневых сценариях атак, которые объединяют техники и уязвимости	Шаблоны атак, описывающие типовые сценарии кибератак, а также связи между шаблонами атак и техниками MITRE ATT&CK
CWE (Common Weakness Enumeration)	Подробное описание типовых ошибок разработки	Описание слабостей, возможные последствия и связь с CVE
CVE (Common Vulnerabilities and Exposures)	Стандарт идентификации и описания уязвимостей в ПО и аппаратных системах	Уникальный идентификатор уязвимости, её описание, метрики CVSS и вероятность эксплуатации
CISA KEV (Known Exploited Vulnerabilities)	Предназначен для повышения защищенности организаций путем выделения наиболее критичных эксплуатируемых уязвимостей	Список эксплуатируемых уязвимостей, дата обнаружения, требуемые сроки устранения и уровень критичности
MITRE ATT&CK	База знаний, описывающая тактики и техники; используется для моделирования атак, анализа инцидентов и разработки мер противодействия	Структурированная информация о поведении атакующих, их целях и методах реализации атак

Таблица 4 – Используемые калькуляторы атак и уязвимостей

Название	Описание	Собираемые данные
CVSS (Common Vulnerability Scoring System)	Стандартная система оценки серьезности уязвимости в ИБ	Качественная оценка серьезности уязвимостей для приоритизации
EPSS (Exploit Prediction Scoring System)	Прогнозирование вероятности эксплуатации уязвимости	Вероятность (от 0 до 1), что уязвимость будет использована в реальной атаке

Таким образом, базы данных и калькуляторы вместе обеспечивают полное понимание угроз, от высокоуровневых шаблонов атак до конкретных уязвимостей. Эти инструменты дополняют друг друга, предоставляя многоуровневую информацию для моделирования атак и оценки рисков.

Однако эти источники данных существуют автономно и не всегда показывают, как уязвимости, слабости и техники связаны между собой в реальных сценариях атак. Это затрудняет анализ сложных многоступенчатых кибератак. Для преодоления этих ограничений используется графовая модель, которая интегрирует данные из CAPEC, CWE, CVE, CISA KEV и MITRE ATT&CK. О ней и пойдет речь дальше. Интеграция представленных ресурсов создаёт эффективную основу для автоматизированного анализа и повышения уровня безопасности информационных систем [67].

1.2 Методологические аспекты интеграции данных о киберугрозах

Интеграция данных из различных источников позволяет создать единую структуру для анализа киберугроз. Для этого данные унифицируются и стандартизируются.

Далее будут рассмотрены взаимосвязи между узлами графа, а именно CAPEC → MITRE ATT&CK, MITRE ATT&CK → CWE и CWE → CVE.

1) CAPEC → MITRE ATT&CK - эта связь указывает, какие техники могут быть реализованы в сценариях кибератаки. Данная связь не имеет веса и используется исключительно для выделения техник в контексте определенной кибератаки.

2) MITRE ATT&CK → CWE - данная связь указывает, какие слабости в архитектуре могут использоваться для реализации атаки определенной техникой. Эта связь имеет вес, равный вероятности использования определенной техникой в ходе кибератаки конкретной слабости в архитектуре атакуемой системы. Она рассчитывается на основе гипотезы, что злоумышленник будет предпочтительнее использовать для кибератаки техникой те слабости архитектуры, которые с наибольшей вероятностью принесут ему успех. Исходя из данной гипотезы становится очевидным, что во время атаки определённой техникой вероятность использования слабости будет прямо пропорциональна вероятности успешной эксплуатации одной из уязвимостей, которые относятся к данной CWE, также данный тип связи подразумевает, что с вероятностью 100 процентов будет избрана одна из соответствующих CWE, так как других вариантов в ходе кибератаки выбранной техникой у злоумышленника нет.

На основе данной информации вес связи должен быть прямо пропорционален P_{CWE} и сумма всех таких связей, исходящих из определенной техники, должна быть равна 1, из чего можно выделить следующую формулу (1) для таких ребер:

$$W_{T \to CWE} = \frac{P_{CWE}}{\sum_{i=1}^{N} P_{CWE_i}}, \qquad (1)$$

где N - количество CWE, которые могут быть использованы в ходе кибератаки через технику T.

3) CWE → CVE - эта связь указывает, с какой вероятностью в ходе атаки, использующей определённую слабость архитектуры системы, злоумышленник проэксплуатирует определенную уязвимость. Данная вероятность, аналогично предыдущей гипотезе, будет прямо пропорциональна метрике EPSS конкретной

уязвимости, и сумма весов таких дуг, исходящих из определённой CWE, будет равна 1. А это означает, что злоумышленник, избрав определённую слабость архитектуры, во время атаки обязательно примет попытку эксплуатировать одну из уязвимостей.

В результате формула (2) расчёта вероятности для данного типа ребра будет следующая:

$$W_{CWE \to CVE} = \frac{P_{CVE}}{\sum_{i=1}^{N} P_{CVE_i}}, \qquad (2)$$

где N - количество CVE, порождённых данной слабостью в архитектуре.

Поскольку CWE порождает множество CVE, то вероятность успешной реализации кибератаки через данную слабость архитектуры будет рассчитываться как вероятность того, что хотя бы одна из связанных CVE будет проэксплуатирована в ходе атаки. Предполагая независимость эксплуатаций отдельных CVE (что справедливо при отсутствии корреляции между уязвимостями), найдём вероятность эксплуатации только одной CVE, что реализуется как обобщённая вероятность единичной эксплуатации уязвимости CVE (EPSS(CVE)), умноженная на вероятность того, что другие CVE не будут проэксплуатированы (1-EPSS(CVE)). Тем самым выведем основную формулу (3):

$$P_{CWE} = \sum_{i=1}^{N} [EPSS(CVE_i) * \prod_{j=1, j \neq i}^{N} (1 - EPSS(CVE_j)]. \qquad (3)$$

Такая структура графа реализует комплексный подход к моделированию атаки на различных уровнях, начиная от более абстрактных CAPEC и техник MITRE ATT&CK до более конкретных уязвимостей (CVE) и их обобщённых классов (CWE), а также позволяет моделировать сценарии для кибератак.

1.3 Преимущества графовой модели для систематизации данных

Графы знаний в области кибербезопасности, представляющие данные в виде графовых моделей, предлагают интегрированные методы для анализа больших массивов сложной информации о киберугрозах, собранной из множества источников. Они могут помочь аналитикам безопасности получить информацию о киберугрозах, достичь глубокого понимания киберситуационной обстановки, визуализировать потоки данных и пути атак [61].

В работе представлен эволюционирующий граф знаний в области кибербезопасности, который интегрирует и связывает критически важную информацию о реальных уязвимостях, слабостях и схематичных атаках из различных публичных источников.

Несмотря на то, что для обеспечения информационной безопасности доступно множество источников информации, они, как правило, изолированы и не могут быть напрямую связаны и интегрированы. Кроме того, они обычно используют разнородные структуры данных, которые семантически не согласованы друг с другом. Интегрированный граф знаний по кибербезопасности предназначен для того, чтобы помочь специалистам по безопасности и аналитикам находить актуальную информацию и понимать контекст [62].

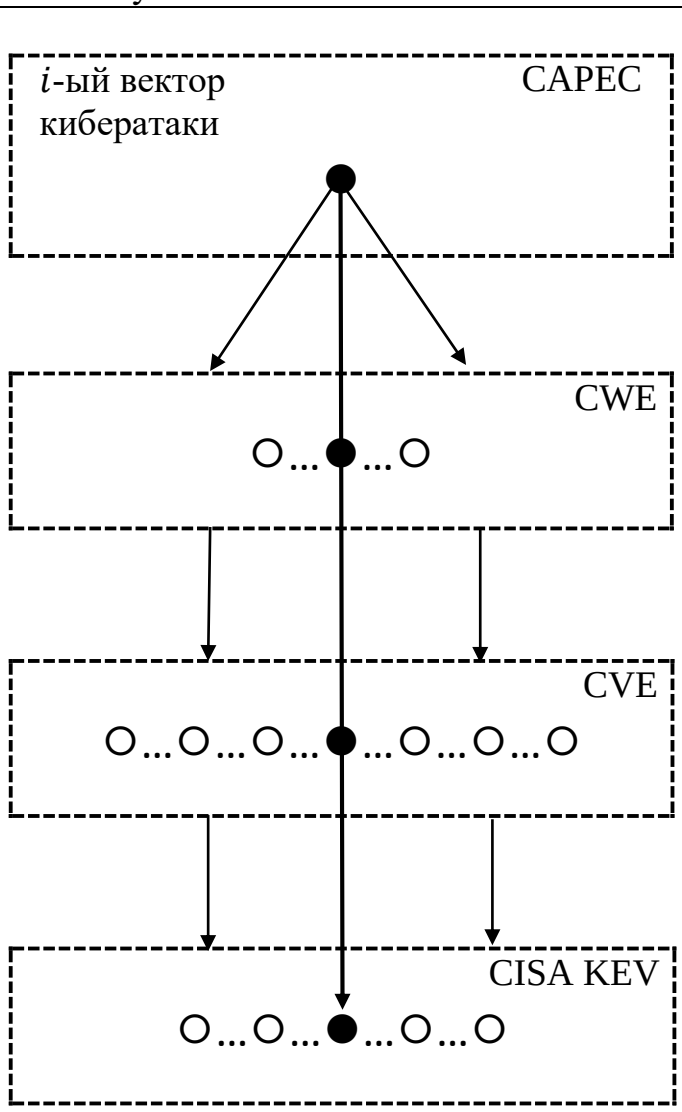
Данный граф, как специфический граф знаний в области безопасности, состоит из узлов и рёбер, которые образуют крупномасштабную семантическую сеть безопасности, предоставляя интуитивно понятный метод моделирования для различных сценариев атак и защиты в реальном мире безопасности. Абстрактные концепции (шаблон атаки, техника, слабость архитектуры, уязвимость) представлены узлами. А взаимосвязи между ними представлены рёбрами. Узлы и рёбра вместе формируют граф знаний.

Важно отметить, что графовая модель позволяет объединять данные с разных уровней абстракции: от высокоуровневых шаблонов атак (CAPEC) до конкретных уязвимостей (CVE). Это создаёт единую систему, которая отражает полную цепочку атаки: от начальных этапов разведки до эксплуатации уязвимостей.

Многие информационные структуры основаны на деревьях [63]. В таблице 5 представлена многоуровневая таксономическая структура, где каждый уровень абстракции детализирует предыдущий:

- вершиной в корневом дереве выступают шаблоны атак CAPEC;
- каждый шаблон декомпозируется на набор техник MITRE ATT&CK;
- каждая техника детализируется до слабостей CWE;
- каждая слабость конкретизируется до уязвимостей CVE.

Таблица 5 - Многоуровневая таксономическая структура

Номер этапа	Графовая иллюстрация процедуры установления соответствия	Сущность осуществляемых этапов
1		Из MITRE ATT&CK выбирается *i*-й вектор атаки (техника), идентифицированный по CAPEC-классификации
2		По классификации CWE определяются ошибки, которые могут быть проэксплуатированы идентифицированным вектором
3		С использованием CVE-ресурса определяются уязвимости, соответствующие избранным программным ошибкам
4		С помощью ресурса CISA KEV осуществляется отбор наиболее актуальных (на текущий момент) уязвимостей

Такая иерархическая структура позволяет последовательно детализировать высокоуровневые сценарии атак до конкретных эксплуатируемых уязвимостей.

Еще одно ключевое достоинство графовой модели заключается в том, что она является динамической и может автоматически обновляться при добавлении новых данных, например, новых уязвимостей и техник. Автоматически будут вычислены новые опасные сценарии кибератак и рекомендованы приоритетные меры противодействия по обнаружению, реагированию и ликвидации последствий возникших угроз.

На рисунке 11 наглядно изображён граф причинно-следственных связей компонентов кибератаки.

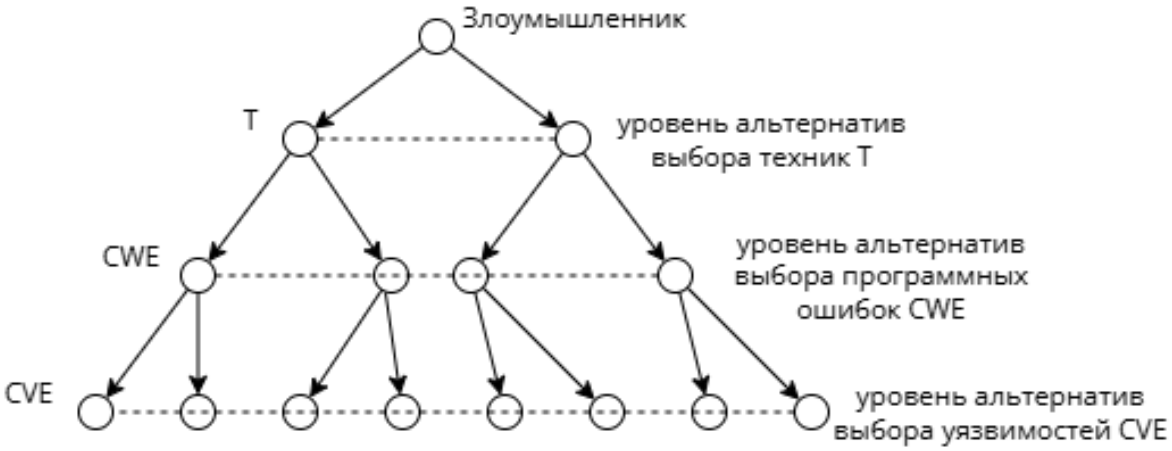


Рисунок 9 – Обобщённый граф причинно-следственных связей компонентов кибератаки

Уникальность созданной графовой модели как инструмента для анализа сложных взаимосвязей между различными компонентами кибератак состоит в том, что можно не только выявлять отдельные уязвимости или техники, но и понимать, как злоумышленники могут комбинировать их для реализации многоступенчатых атак.

В таблице 6 продемонстрировано соответствие параметров вероятных сценариев реализации кибератаки заданного шаблона (CAPEC). В ней указаны следующие данные:

1) Шаблон атаки (CAPEC) – представляет общий сценарий атаки;

2) Техники (T_1,…,T_i,…,T_m) – конкретные действия злоумышленников для реализации шаблона атаки, они связаны с конкретными уязвимостями;
3) Уязвимости (CVE_{1k},…,CVE_{in},…,CVE_{ml}) – конкретные точки входа для злоумышленников, это отражает взаимосвязь между техниками и уязвимсост;
4) Критичность уязвимостей (K_{1k},…,K_{in},…,K_{ml})– оценивает серьезность слабостей системы, эти значения используются для расчета общего риска атаки;
5) Вероятность эксплуатации (p_{1k},…,p_{in},…,p_{ml}) – предсказывает реальную вероятность использования уязвимости, эти данные важны для оценки опасности каждой уязвимости.

Таблица 6 – Соответствие параметров вероятных сценариев реализации кибератаки заданного шаблона

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы
CAPEC	T_1	CVE_{11}	K_{11}	P_{11}
		…	…	…
		CVE_{1k}	K_{1k}	P_{1k}
	…			
	T_i	CVE_{i1}	K_{i1}	P_{i1}
		…	…	…
		CVE_{in}	K_{in}	P_{in}
	…			
	T_m	CVE_{m1}	K_{m1}	P_{m1}
		…	…	…
		CVE_{mL}	K_{mL}	P_{mL}
m – количество используемых для реализации шаблона атаки техник				

Вышеуказанная таблица предоставляет исходные данные, которые затем преобразуются в графовую модель, изображенную на рисунке 10.

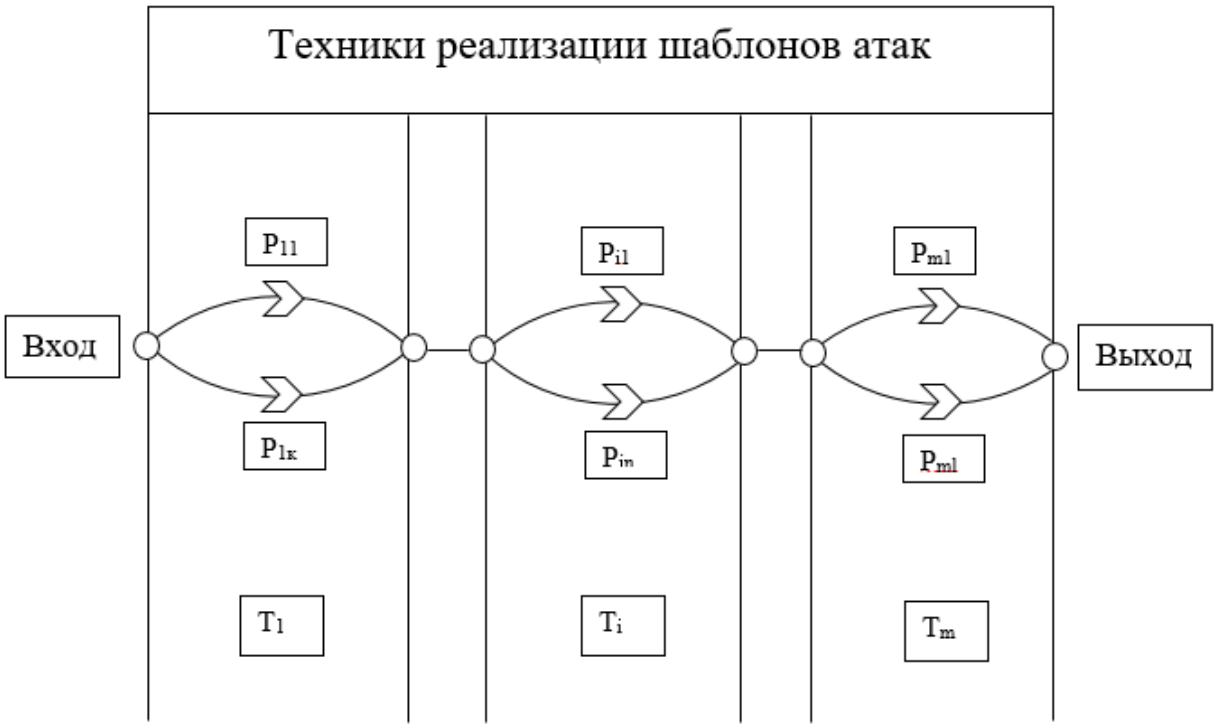


Рисунок 10 – Графовая модель вероятных сценариев реализации обобщенного шаблона кибератаки, представленного в таблице 6

Такая графовая модель является мощным инструментом для анализа киберугроз. Во-первых, она визуализирует сложные взаимосвязи между компонентами атаки, во-вторых, позволяет оценивать вероятности успешной реализации сценариев, в-третьих, обеспечивает динамическое обновление данных.

Ещё одно преимущество созданной графовой модели заключается в том, что она предоставляет возможность для декомпозиции рисков – разделения общего риска на составляющие, такие как целостность, доступность и конфиденциальность информации. Это преимущество особенно важно для анализа киберугроз, поскольку позволяет более точно оценить последствия атак и разработать целевые меры противодействия.

Декомпозиция рисков основана на идее, что общий риск, связанный с уязвимостью или сценарием атаки, не является однородным. Он распределяется между тремя ключевыми компонентами безопасности [64]:

1) Конфиденциальность – способность системы защищать данные от несанкционированного доступа;
2) Целостность – способность системы предотвращать несанкционированные изменения данных;
3) Доступность – способность системы обеспечивать постоянный доступ к данным и ресурсам.

Графовая модель позволяет выделить эти компоненты, используя данные из калькулятора CVSS (Common Vulnerability Scoring System), с помощью которого оценивается серьезность уязвимостей. А, в свою очередь, уязвимость обладает двумя главными свойствами: вероятность эксплуатации в ходе кибератаки (на момент расчета рисков она уже известна) и критичность результатов эксплуатации в ходе кибератаки (она же определяется на основе двух главных факторов – показатели CVSS и наличие CVE в CISA KEV).

Базовый показатель CVSS состоит из двух основных групп метрик:

- метрики атаки (характеризуют условия и возможности для реализации уязвимости);

- метрики воздействия (указывают на последствия, которые могут быть вызваны при успешной эксплуатации уязвимости, влияющие на три базовые характеристики информации, упомянутые ранее: конфиденциальность, целостность и доступность).

Основной недочет системы CVSS заключается в том, что предоставляется лишь общая оценка риска, которая не дает детального представления о том, какой именно компонент безопасности наиболее подвержен угрозе, что важно для эффективного управления рисками и принятия обоснованных решений по защите информации на основе осведомленности о том, какую именно часть инфраструктуры и какие конкретные аспекты безопасности затрагивает та или иная уязвимость.

Избранный подход о декомпозиции базовой оценки на метрики, соответствующие каждому из базовых свойств безопасности, достаточно важен с точки зрения обеспечения информационной безопасности, так как он приведет к понятию того, какая из компонент безопасности будет подвергаться наибольшему риску. И для реализации этого подхода был избран метод распределения вклада каждой компоненты безопасности в итоговую оценку, основанный на теории кооперативных игр, в точности – на методе Шепли, так как именно данный метод используется для справедливого распределения общего вклада в результат между участниками, делая выводы исходя из индивидуального вклада участников. В контексте данной работы участниками выступают три компоненты безопасности – конфиденциальность, доступность и целостность, а непосредственно результатом является сама общая оценка риска, полученная из базового показателя CVSS.

Данный метод Шепли обладает рядом математических свойств [65]:

1) Эффективность – сумма всех индивидуальных вкладов участников должна быть равна общему результату;
2) Симметрия – если два участника вносят одинаковый вклад в результат, то они обязательно получают одинаковую оценку вклада;
3) Нулевой вклад – если же участник никак не повлиял на результат, то его вклад равен нулю.

Данные свойства очень важны в декомпозиции рисков, так как они могут гарантировать объективное и корректное распределение значения CVSS между отдельными характеристиками безопасности, без смещения или произвольного назначения весов. Таким образом, применение метода Шепли для разделения базовой оценки CVSS на компоненты, соответствующие целостности, доступности и конфиденциальности, открывает новые возможности для более глубокого анализа уязвимостей и повышает эффективность процессов обеспечения информационной безопасности.

Также важной особенностью графовой модели является её способность к автоматизации анализа и генерации сценариев. Во-первых, ручной анализ больших объёмов данных требует значительных временных затрат и часто приводит к

ошибкам. А автоматизация позволяет быстро обрабатывать данные, строить цепочки атак за считанные секунды, своевременно реагировать на новые угрозы. Применение алгоритмов и нейросетевых моделей позволяет существенно снизить риск ошибок, связанных с человеческим фактором. Анализ существующих баз данных, их интеграция с системами оценки уязвимостей (CVSS и EPSS), а также использование разработанной графовой модели для объединения информации демонстрируют ключевые преимущества предложенного подхода. К ним относятся:

1) **Целостный подход к анализу угроз** — модель объединяет данные с различных уровней абстракции (CAPEC, CWE, CVE, CISA KEV, MITRE ATT&CK), что обеспечивает возможность изучения сложных взаимосвязей между элементами кибератак.
2) **Автоматизация анализа и построения сценариев атак** — благодаря использованию алгоритмов машинного обучения (рассматриваемых в следующей главе) можно автоматически формировать цепочки атак, учитывая вероятности переходов между техниками и уязвимостями. Это значительно сокращает время анализа и уменьшает вероятность ошибок, характерных для ручного подхода.

Декомпозиция рисков – модель предоставляет возможность разделения общего риска на компоненты, такие как конфиденциальность, целостность и доступность информации, что повышает точность оценки последствий атак.

На основании вышеизложенного можно сделать следующий вывод: предложенная графовая модель является универсальным и гибким инструментом для анализа киберугроз и генерации мер противодействия. Она сочетает в себе теоретическую проработанность и практическую применимость, что делает её особенно ценной в условиях быстрого развития киберугроз.

2 Методическое обеспечение построения графовой модели для анализа киберугроз

2.1 Формализация структуры графовой модели

Центральным компонентом разработанной модели для исследования киберугроз является графовая база данных. Её основная функция заключается в объединении информации из множества источников с различными уровнями детализации, что создаёт основу для многоаспектного анализа потенциальных рисков. Далее подробно будут рассмотрены ключевые составляющие и базовые принципы формирования данной структуры.

В данной работе представлено решение, которое включает в себя ориентированный мультиграф G = (N,E), где N – множество узлов (вершин), представляющих различные компоненты кибератак, E – множество рёбер, определяющих связи между узлами.

Узлы графа интегрируют данные из популярных стандартов в области кибербезопасности, широко развернутые в прошлой главе:

1) CAPEC (Common Attack Pattern Enumeration and Classification) – шаблоны атак, описывающие типовые сценарии кибератак;
2) CWE (Common Weakness Enumeration) – классификация слабостей программного обеспечения и архитектуры системы;
3) CVE (Common Vulnerabilities and Exposures) – уязвимости информационных активов;
4) CISA KEV (Known Exploited Vulnerabilities) – наиболее актуальные (на текущий момент) уязвимости, которые встречаются в реальных атаках;
5) MITRE ATT&CK – техники, применяемые на этапах жизненного цикла кибератаки.

Каждый узел содержит дополнительную информацию, называемую атрибутами узлов. Когда один из этих атрибутов используется для ранжирования узла, это называется весом узла, а граф с весами называется взвешенным [66].

Характеристики и метрики для узлов CVE:

1) Узлы CVE (уязвимости):

Основная метрика – вероятность успешной эксплуатации уязвимости во время кибератаки. Для расчета данной метрики используется вышеупомянутая система EPSS (Exploit Prediction Scoring System), предназначенная для прогнозирования вероятности эксплуатации уязвимости в реальных условиях. Данная система основана на машинном обучении и учитывает исторические данные о реальных эксплойтах уязвимостей, опубликованных через такие платформы по кибербезопасности, как: ExploitDB (одна из самых больших баз эксплойтов), Metasploit (самый популярный и поддерживаемый фреймворк для тестирования на проникновение и разработки эксплойтов) и данные об инцидентах кибербезопасности от организации, занимающейся кибербезопасностью, реагированием на инциденты и анализом уязвимостей, CERT (Computer Emergency Response Team). Из-за того, что EPSS фокусируется на реальной вероятности эксплуатации уязвимости, а не только на её технической серьёзности, данная система является приоритетной для определения вероятности эксплуатации уязвимостей.

2) Узлы CWE (слабости):

Поскольку CWE порождает множество CVE, то вероятность успешной реализации атаки через данную слабость будет рассчитываться как вероятность того, что хотя бы одна из связанных CVE будет проэксплуатирована в ходе атаки.

3) Узлы MITRE ATT&CK (техники):

Вероятность успешного использования техники рассчитывается через вероятности связанных слабостей (CWE).

4) Узлы CAPEC (шаблоны атак):

Эти узлы описывают высокоуровневые сценарии атак. Используются для идентификации возможных техник (MITRE ATT&CK), которые могут быть применены в рамках шаблона.

Однако сами по себе узлы, представляющие компоненты кибератак (CVE, CWE, техники MITRE ATT&CK), не отражают полной картины угроз. Для понимания того, как эти компоненты взаимодействуют между собой в реальных

сценариях атак, необходимо рассмотреть рёбра графа, которые определяют связи и последовательности действий злоумышленников.

Рёбра в графе представляют связи между узлами, которые отражают логические или вероятностные взаимодействия между компонентами кибератаки. Каждое ребро имеет:

1) Направление – рёбра в графе являются ориентированными, что указывает на последовательность действий (например, «техника → техника» или «CWE → CVE»;
2) Вес – он отражает вероятность перехода от одного узла к другому;
3) Тип – рёбра могут быть разными в зависимости от типа узлов, которые они соединяют.

На основе полученной графовой базы данных вычисляются основные веса узлов графа, а именно: риск для конфиденциальности, риск для доступности и риск для целостности защищаемой информации.

Риск - это потенциальная возможность причинения вреда в результате реализации какой-либо угрозы к какому-либо активу через существующую уязвимость [68]. Поэтому риск в контексте данного анализа будет считаться именно потенциальным ущербом от реализации кибератаки. В результате имеем следующую формулу (4) риска:

$$\overline{Risk} = P \times \overline{U} \times C, \qquad (4)$$

где P - вероятность реализации угрозы через уязвимость;

$\overline{U}$ - нормированный ущерб актива в результате реализации угрозы;

C - ценность актива.

Поскольку ценность актива определяется особенностями архитектуры информационной системы, то очевидно, что разработка универсальной и гибкой системы оценки рисков на основе исходной формулы становится сложной задачей. Для упрощения модели можно временно сократить ценность актива, оставив только нормированный ущерб, тем самым полив нормированный риск, что даст системе

универсальность и гибкость. Таким образом, формула (5) нормированного риска, на основе которой будет строиться весь подход к анализу, приобретает следующий вид:

$$\overline{Risk} = P \times \overline{U}. \qquad (5)$$

На основании определения риска в данной системе фундаментальной единицей атаки являются уязвимости, используя взаимосвязи с которыми, можно будет получить более расширенный риск, связанный с CWE, техниками и сценариями кибератак. Важно более подробно рассмотреть главные свойства уязвимостей, а именно:

- вероятность эксплуатации уязвимости в ходе кибератаки - это свойство узла рассчитывается в ходе интеграции данных в граф, используя систему EPSS;
- нормированный ущерб актива в результате эксплуатации уязвимости - данное свойство для уязвимости CVE одним из основных подходов принято определять на основе двух показателей CVSS.

Основной недочет системы CVSS заключается в том, что предоставляется общий ущерб активу в результате эксплуатации уязвимости, что не дает возможности оценить влияние на каждое из перечисленных свойств безопасности информации, что важно для эффективного управления рисками и принятия обоснованных решений по защите информации на основе осведомлённости в том, какую именно часть инфраструктуры и какие конкретные аспекты безопасности затрагивает та или иная уязвимость.

В результате подробного изучения структуры и формул расчёта базовой оценки в различных версиях CVSS было сделано заключение о возможности её декомпозиции на метрики, соответствующие каждому из базовых свойств безопасности информации, а именно: конфиденциальности, доступности и целостности. Это, в свою очередь, даёт возможность учитывать, какой из компонентов безопасности будет подвергаться наибольшему риску.

Для реализации такого подхода к декомпозиции базовой оценки CVSS был избран метод распределения вклада каждой компоненты безопасности в базовую оценку, основанный на теории кооперативных игр, а именно - на методе Шепли, так как именно данный метод используется для справедливого распределения общего вклада в результат между участниками, делая выводы исходя из маргинальных вкладов участников во всех возможных комбинациях. Далее будет более подробно рассмотрен выше упомянутый метод.

2.2 Методика анализа рисков на основе графовой модели

Анализ рисков является ключевым этапом в оценке потенциальных угроз информационной системы. В рамках предложенной графовой модели данный процесс реализуется через декомпозицию данных CVSS и использование метода Шепли для распределения рисков между компонентами безопасности.

Метод Шепли является идеальным инструментом для декомпозиции базового показателя CVSS. В контексте анализа рисков участники - это базовые свойства безопасности: конфиденциальность, доступность и целостность.

Метод Шепли обладает рядом значимых математических свойств [30], среди которых:

1) **Эффективность** — сумма индивидуальных вкладов всех участников точно соответствует общему результату;
2) **Симметрия** — участники, вносящие равный вклад, получают одинаковую оценку;
3) **Нулевой вклад** — если участие одного из игроков не влияет на результат, его вклад считается равным нулю.

Эти свойства гарантируют объективное и корректное распределение значения CVSS между компонентами безопасности, исключая произвольное назначение весов. Что очень помогает в данной работе.

Тогда становится возможным рассчитать значения Шепли по следующей формуле (6):

$$\phi_i(v) = \frac{1}{n!}\sum_{p \in (\text{перестановки } N)} [v(S_p(i) \cup \{i\}) - v\left(S_p(i)\right)], \qquad (6)$$

где $\phi_i(v)$ - вклад метрики i∈{К,Ц,Д} в CVSS Base Score;

$S_p(i)$ - множество метрик, добавленных до i в перестановке p;

$v(S)$ - функция расчёта Base Score при наличии только метрик из S.

В результате чего Base Score рассматривается как характеристическая функция кооперативной игры, где игроки - это метрики конфиденциальности, доступности и целостности.

Используя данную формулу, рассчитываются маргинальные вклады в CVSS Base Score для каждой из метрик К, Д, Ц. Зная эти значения Шепли, необходимо их нормализовать, для этого необходимо рассчитать суммарное влияние по формуле (7):

$$\phi_{\text{кцд}} = \phi_{\text{к}} + \phi_{\text{ц}} + \phi_{\text{д}}. \qquad (7)$$

После вычисления суммарного влияния на Base Score можно получить веса для каждой метрики по следующей формуле (8):

$$w_{\text{К,Ц,Д}} = \frac{\phi_{\text{к,ц,д}}}{\phi_{\text{кцд}}}. \qquad (8)$$

Таким образом, на основе рассчитанных весов для каждой метрики появляется возможность определить значение CVSS для отдельных компонентов по следующей формуле (9):

$$CVSS_{\text{К,Ц,Д}} = CVSS_{Base\ Score} * w_{\text{К,Ц,Д}}. \qquad (9)$$

Но из-за того, что оценка CVSS является статическим показателем потенциального ущерба, то появляется потребность в подкреплении данного значения динамической информацией, позволяющей адаптироваться к эволюционирующим условиям киберпространства. Такой информацией можно считать наличие уязвимости в базе данных CISA KEV, что указывает на её высокую степень серьёзности и потенциальную опасность для информационной безопасности из-за приоритетности её выбора злоумышленником [10].

Как было сказано выше, CISA KEV (Cybersecurity&Infrastructure Security Agency Known Exploited Vulnerabilities) является официальной базой данных об уязвимостях, которые в действительности уже были эксплуатированы злоумышленниками в ходе кибератак.

Выбор этой базы данных как одного из факторов потенциального ущерба уязвимости обусловлен тем, что CVE в нём имеют высокую релевантность и актуальность, гарантируя, что все уязвимости были подтверждены в реальных кибератаках. Также исследования показали, что уязвимости, включенные в базу данных CISA KEV, устраняются в среднем в 3.5 раза быстрее, чем другие известные уязвимости, не входящие в этот список. Такая динамика объясняется тем, что и специалисты по безопасности, и злоумышленники уделяют повышенное внимание уязвимостям из каталога CISA KEV, поскольку их наличие указывает на реальную угрозу компрометации систем.

Одним из важных коэффициентов является относительная критичность уязвимости, которая определяется как отношение критичности CVE к сумме критичностей всех CVE, которые могут быть проэксплуатированы в ходе рассматриваемой атаки [70]. Это значение учитывает вес уязвимости в контексте всего множества возможных CVE, что важно для эффективной оценки с целью реализации качественных мер противодействия кибератакам.

В результате составлена итоговая формула (10) нахождения нормированного ущерба для уязвимости:

$$\overline{U_{\text{К,Ц,Д}}} = \frac{CVSS\,(CVE_{ij})}{10}, \qquad (10)$$

где $CVSS\,(CVE_{ij})$ – критичность эксплуатации уязвимости CVE по версии калькулятора EPSS с областью определения {0; 10}.

Таким образом, получив главные свойства уязвимости для нахождения потенциального ущерба при эксплуатации уязвимости, можно описать итоговую формулу (11) для расчёта потенциального риска конфиденциальности, целостности или доступности информации в ходе эксплуатации уязвимости:

$$\overline{Risk_{CVE}^{\text{К,Ц,Д}}} = EPSS * \overline{U_{\text{К,Ц,Д}}}\,. \qquad (11)$$

Исследуемый подход позволяет создавать многомерные графы, учитывающие потенциальный нормированный ущерб для конфиденциальности, целостности и доступности.

Теперь, зная риски узлов CVE в графе и имея взаимосвязи, характеризующие вероятность выбора злоумышленником между уязвимостями и порождающими их CWE, становится возможным рассчитать нормированный риск (потенциального нормированного ущерба) кибератаки, использующей определённую слабость архитектуры системы при эксплуатации уязвимости. Данный риск вычисляется по формуле 12:

$$\overline{Risk_{CWE}^{\text{К,Ц,Д}}} = \Sigma_{i=1}^{N} \quad \overline{Risk_{CVE_i}^{\text{К,Ц,Д}}} * W_{CWE \to CVE_i}, \qquad (12)$$

где N – количество CVE, связанных с CWE;

$W_{CWE \to CVEi}$ – вероятность выбора CVE злоумышленником, рассчитанная при создании графа.

Получив нормированные риски кибератак, использующих слабости в архитектуре, которые учитывают в себе риски кибератак, эксплуатирующих определённые уязвимости, можно рассчитать потенциальный нормированный риск,

наносимый в результате реализации кибератак, выполненных определёнными техниками MITRE ATT&CK, что выполняется по формуле 13:

$$\overline{Risk_T^{К,Ц,Д}} = \Sigma_{i=1}^{N} \quad \overline{Risk_{CWE_i}^{К,Ц,Д}} * W_{T \to CWE_i}, \qquad (13)$$

где N – количество CWE, связанных с техникой;

$W_{T \to CWEi}$ – вероятность выбора CWE злоумышленником, рассчитанная при создании графа.

2.3 Динамическое обновление данных в графовой модели

Графовая модель является динамической структурой, способной адаптироваться к изменениям в киберугрозной среде. В отличие от статических систем анализа (например, CVSS), данная разработанная модель позволяет автоматически интегрировать новые данные и обновлять существующие связи в реальном времени. Это особенно важно в условиях быстро меняющейся киберобстановки, где появление новых уязвимостей, техник и шаблонов атак требует оперативного реагирования.

Следует отметить, что динамическое обновление графовой модели основывается на интеграции данных из различных источников:

1) Новые уязвимости (CVE) добавляются в соответствующую базу данных ежедневно. Эти данные автоматически интегрируются в граф;
2) Список уязвимостей, которые уже были эксплуатированы, регулярно обновляется (CISA KEV). Добавление таких уязвимостей в граф повышает приоритет их анализа;
3) Вероятности эксплуатации уязвимостей (EPSS) обновляются на основе машинного обучения;
4) Техники и тактики (MITRE ATT&CK) злоумышленников могут быть дополнены новыми записями, что требует обновления связей в графе;

5) Также появление новых шаблонов атак (CAPEC) или слабостей (CWE) влияет на структуру графа.

Динамическое обновление данных в графовой модели является одним из ключевых преимуществ, так как оно имеет стратегическое значение для современных систем кибербезопасности, где оперативность и точность реакции на новые угрозы напрямую влияют на уровень защищённости информационных активов. Можно выделить следующие достоинства динамического обновления [32]:

1) **Актуальность данных** - говорит о том, что граф всегда содержит самую актуальную информацию о киберугрозах (происходит интеграция новых уязвимостей, техник и шаблонов атак сразу после их появления в открытых источниках), что критически важно в условиях постоянного появления новых угроз;

2) **Гибкость модели** — предложенная графовая модель обладает высокой адаптивностью к изменениям в киберугрозной среде, что делает её универсальным инструментом для анализа рисков. При обнаружении новой уязвимости система не только интегрирует её в граф, но и определяет связи с уже известными техниками и шаблонами атак, что позволяет заранее оценить потенциальные векторы новых атак;

3) **Оперативность анализа** — автоматическое обновление данных позволяет значительно ускорить процесс анализа новых уязвимостей и сценариев атак. При этом система способна практически в реальном времени предлагать приоритетные меры реагирования, что особенно актуально в условиях быстроразвивающихся, многоступенчатых атак;

4) **Высокая точность оценки рисков** — за счёт автоматизации снижается вероятность ошибок, связанных с человеческим фактором. Дополнительно использование таких инструментов, как CVSS и EPSS, обеспечивает более точную оценку вероятности эксплуатации уязвимостей и потенциального ущерба.

Таким образом, преимущество динамического обновления данных заключается не только в повышении эффективности анализа киберугроз, но и в создании основы для разработки стратегических решений в области защиты информационных систем. Это делает графовую модель мощным инструментом для современных специалистов по кибербезопасности.

3 Методология автоматической генерации сценариев кибератак

3.1 Построение цепочек кибератак на основе графовой модели

Для расчёта рисков сценариев кибератак используются последовательности техник Mitre Attack, найденные через специально разработанный граф, реализующий цепи Маркова, который состоит из техник, относящихся к определённым тактикам Mitre Attack, а также дополнительных узлов СТАРТ и СТОП, которые показывают начало и конец любого сценария кибератаки.

Для реализации графовой модели, описывающей сценарии кибератак, используется специальный тип ребра “техника → техника”. Данное ребро указывает последовательность действий злоумышленника и имеет вес, равный вероятности перехода от одной техники к другой. Расчёт веса основывается на предположении, что злоумышленник выбирает технику с наибольшей вероятностью успешного завершения атаки. Это позволяет строить реалистичные цепочки атак и оценивать их вероятность. В результате вес данной связи рассчитывается по следующей формуле (14):

$$W_{T \to T_i} = \frac{P_{T_i}}{\sum_{j=1}^{N} P_{T_j}}, \qquad (14)$$

где T_i - техника, вес ребра между которой рассчитывается от текущей техники T;

N - количество техник, в которые текущая техника имеет возможность перейти в ходе атаки.

Техники в графе соединены между собой в определённой последовательности, которая сформирована на основе соответствующих им тактик, взаимосвязи между которыми можно увидеть в приложении А.

Поиск сценариев ведётся через поиск всевозможных путей в графе от узла СТАРТ до узла СТОП. Вероятность бесконечных циклов избегается путём

применения пороговых значений вероятности реализации сценария. Вероятность реализации всего сценария, очевидно, будет равна (формула 15):

$$P_{\text{сценар.}} = \prod_{i=1}^{N} \quad P(T_i \rightarrow CVE_{ij}), \qquad (15)$$

где N - количество используемых техник в сценарии.

В свою очередь, $P(T_i \rightarrow CVE_{ij})$ при j = 1(1)m, где m – количество эксплуатируемых техникой i уязвимостей, определяется из ресурса EPSS и/или критичностей K_{ij} вышеописанных уязвимостей из ресурса CVSS (формула 16):

$$P\left(T_i \rightarrow CVE_{ij}\right) = \frac{K_{ij} \times \delta_{ij}}{\sum_{j=1}^{m} K_{ij} \times \delta_{ij}}, \qquad (16)$$

имея ввиду, что внимание злоумышленника, прежде всего, привлечёт наибольшая из них. В выражении (16) коэффициент δ_{ij} обозначает возможность отбора рассматриваемых уязвимостей (δ_{ij} = 0 или δ_{ij} = 1) по критериям популярности эксплуатации уязвимости и/или наличия таковой в конкретно рассматриваемой системе.

Нормированный риск сценария же определяется как сумма произведений нормированного риска техники во время её выполнения на вероятность сценария в момент, когда эта техника была последней техникой этого сценария, это отражено в формуле 17:

$$Risk_{\text{сценар.}} = \frac{\sum_{i=1}^{n}(\prod_{j=1}^{i}[P_{Tj-1 \rightarrow Tj}] \times Risk_{Ti})}{n}, \qquad (17)$$

где n - количество техник в сценарии;

$\prod_{j=1}^{i}[P_{Tj-1 \rightarrow Tj}]$ – вероятность применения злоумышленником техники i в контексте сценария кибератаки.

Построение цепочек кибератак позволяет выявить возможные сценарии атак злоумышленников. Однако, учитывая большое количество потенциальных

сценариев, возникает необходимость в их ранжировании по степени риска. Это позволяет сосредоточить усилия на противодействии наиболее вероятным и опасным атакам, что особенно важно в условиях ограниченных ресурсов.

3.2 Ранжирование сценариев кибератак по степени риска

Современные кибератаки характеризуются высокой степенью сложности и многоступенчатостью, что приводит к образованию огромного количества потенциальных сценариев атак. Даже при наличии выгруженных в графовую базу данных 823 техник (MITRE ATT&CK) количество возможных комбинаций и последовательностей их применения может достигать астрономических значений. В таких условиях полный анализ всех возможных сценариев становится практически невозможным как с точки зрения вычислительных ресурсов, так и с точки зрения временных затрат.

В связи с ростом количества потенциальных атак возрастает потребность в эффективном механизме, позволяющем выделять наиболее опасные сценарии для приоритетного анализа и реагирования. Ключевую роль в этом процессе играет ранжирование сценариев по уровню риска.

Ранжирование помогает структурировать все возможные варианты атак и выделить те, которые представляют наибольшую угрозу для информационной системы [72]. Оно основано на комплексной оценке ряда факторов, таких как вероятность успешного выполнения атаки, возможный ущерб и значимость целевых информационных ресурсов.

Благодаря такому подходу специалисты по кибербезопасности могут сосредоточить усилия на нейтрализации наиболее критичных угроз, которые требуют быстрого реагирования. Это особенно актуально в условиях ограниченных ресурсов и необходимости оперативного принятия решений, когда важно эффективно распределить доступные средства защиты.

Согласно формуле (5), в процессе ранжирования сценариев кибератак учитываются следующие ключевые параметры:

1) **Вероятность реализации** — отражает вероятность успешного выполнения каждой техники в цепочке атаки и является основным критерием при оценке степени угрозы;
2) **Ожидаемый ущерб** — измеряет потенциальные последствия атаки, оцениваемые по степени воздействия на конфиденциальность, целостность и доступность информации;
3) **Нормированный риск** — сводный показатель, объединяющий вероятность реализации и уровень ущерба, позволяющий объективно сравнивать сценарии между собой и выстраивать их по степени критичности.

Таким образом, ранжирование по степени риска является важнейшим этапом анализа киберугроз. Оно позволяет сконцентрировать усилия на наиболее опасных сценариях и снизить потенциальные потери.

После выполнения ранжирования становится необходимым разрабатывать конкретные меры противодействия для наиболее критичных сценариев. С этой целью в графовую модель внедряются данные о соответствующих мерах защиты, которые позволяют сократить вероятность реализации атаки или уменьшить её последствия.

3.3 Интеграция данных о мерах противодействия в графовую модель

Интеграция информации о мерах защиты — важный шаг в построении комплексной стратегии безопасности информационных систем. Эти данные позволяют не только выявлять потенциальные угрозы, но и определять конкретные действия для нейтрализации угроз на каждом этапе атаки.

Для каждого выявленного критичного сценария подбирается набор контрмер, которые могут быть применены с целью предотвращения атаки или снижения её последствий. Это повышает общий уровень защищённости системы и обеспечивает более оперативную реакцию на инциденты.

Источниками таких данных служат, в частности, рекомендации из базы MITRE ATT&CK, а также патчи и обновления, относящиеся к конкретным

уязвимостям (CVE). Интеграция этой информации в графовую модель позволяет автоматически формировать пакеты защитных мер для конкретных атакующих цепочек.

Каждая техника, представленная в графовой модели, связывается с набором соответствующих контрмер, направленных на её блокировку. Эффективность каждой меры оценивается по её способности снижать вероятность успешной реализации техники или ограничивать возможный ущерб.

Таким образом, включение информации о мерах противодействия в графовую модель обеспечивает целостный подход к обеспечению кибербезопасности. Этот подход не только выявляет угрозы, но и предлагает практические способы их устранения. Подробное описание методики автоматизированного формирования защитных мер представлено в следующей главе.

4 Методология автоматизированной генерации мер противодействия кибератакам

4.1 Этапы жизненного цикла разработки мер противодействия

Для наиболее эффективного противодействия возникающим кибератакам особую важность имеет подход в разработке комплексных мер противодействия кибератакам, которые охватывают различные фазы жизненного цикла инцидента. Всего выделяется три базовых свойства защиты информации [73]:

1) Меры обнаружения — это действия, направленные на своевременное выявление признаков кибератак в информационной системе. Основная цель данных мер — обеспечить максимально раннее обнаружение угроз, что позволяет оперативно начать реагирование и снизить возможный ущерб;

2) Меры реагирования — это шаги, предпринимаемые после выявления инцидента, с целью быстрой локализации атаки и предотвращения её дальнейшего развития. Эти меры критически важны для минимизации ущерба и недопущения распространения угрозы;

3) Меры ликвидации последствий — включают действия, направленные на восстановление нормального функционирования системы после атаки, а также на снижение долгосрочных негативных последствий. Кроме того, эти меры способствуют повышению устойчивости инфраструктуры к возможным будущим атакам.

Разработка эффективных мер противодействия — это комплексный и поэтапный процесс, включающий анализ уязвимостей, их классификацию, формирование базы знаний и автоматизированную генерацию защитных решений. Каждый из этапов играет ключевую роль и основан на научно обоснованных подходах, что обеспечивает создание надёжной системы защиты информационных активов. Ниже приведено подробное описание каждого этапа жизненного цикла формирования мер противодействия:

1) Анализ уязвимостей – на данном этапе проводится детальный анализ уязвимостей системы, включая их классификацию по типам (CWE), оценку вероятности эксплуатации (EPSS) и уровень критичности (CVSS).
2) Категоризация уязвимостей – уязвимости группируются по семантическому смыслу с использованием методов машинного обучения и затем каждая категория уязвимостей анализируется для определения общих подходов к их нейтрализации.
3) Формирование базы знаний о мерах противодействия – на данном этапе создаётся база знаний, которая содержит информацию о рекомендуемых мерах противодействия для каждой категории уязвимостей.
4) Генерация мер противодействия – на заключительном этапе на основе анализа уязвимостей и базы знаний формируются конкретные меры противодействия, а именно: меры обнаружения (включают использование систем обнаружения вторжений (IDS), мониторинг сетевой активности и анализ журналов событий), меры реагирования (включают блокировку IP-адресов, изоляцию заражённых систем и отключение компрометированных учётных записей), меры восстановления (включают восстановление данных из резервных копий и устранение последствий атаки).

Таким образом, этапы жизненного цикла разработки мер противодействия представляют собой комплексный процесс, который включает анализ уязвимостей, категоризацию данных, формирование базы знаний и генерацию мер противодействия.

4.2 Методические основы автоматизации генерации мер противодействия

Методические основы автоматизации генерации мер противодействия кибератакам представляют собой комплексный подход, который объединяет использование графовой модели, алгоритмов машинного обучения и анализа данных для формирования эффективных рекомендаций по защите информационных систем.

Основная цель заключается в том, чтобы минимизировать временные затраты на анализ угроз и обеспечить оперативное реагирование на инциденты кибербезопасности.

Автоматизация процесса генерации мер противодействия основана на следующих ключевых принципах:

1) Генерация категорий уязвимостей по семантическому смыслу;
2) Генерация мер противодействия для категорий уязвимостей;
3) Категорирование уязвимостей по семантическому смыслу.

Для более полного понимания процесса автоматизации разработки мер противодействия необходимо подробно рассмотреть его ключевые принципы.

1) **Генерация категорий уязвимостей на основе семантического анализа** — на первом этапе автоматизации выполняется классификация уязвимостей по их смысловому содержанию. С помощью методов обработки естественного языка (NLP) анализируется текстовое описание уязвимостей, что позволяет объединять их в группы с общими характеристиками. Такая категоризация облегчает разработку универсальных мер противодействия, применимых ко всей группе, и способствует стандартизации подходов к защите.

Для выявления категорий используется ансамбль моделей машинного обучения (CySecBERT [74] и TF-IDF [75]). Эти модели анализируют текстовые описания уязвимостей (например, CVE) и находят скрытые связи между ними.

CySecBERT является специализированной версией модели BERT, которая относится к классу архитектур на основе трансформеров и предназначена для глубокого анализа естественного языка в сфере кибербезопасности. Данная модель способна учитывать двусторонний контекст, так как она одновременно анализирует слова как в прямом, так и в обратном направлении, что нужно для того, чтобы понимать семантическую связь между элементами предложения. Из-за того, что BERT основан на трансформерах – нейросетевой структуре, в которой каждый элемент входной последовательности взаимодействует с каждым элементом выходной последовательности через механизмы внимания, что даёт данной модели следующие ключевые преимущества [74,76]:

- параллелизм – данная особенность даёт возможность обработки всех слов в тексте одновременно, что позволяет значительно ускорить вычисления;

- обработка длинных текстов – механизмы внимания позволяют данной модели эффективно улавливать зависимости даже между далеко удалёнными элементами анализируемого текста;

- поддержка предобучения – у BERT есть возможность заранее обучиться на больших наборах текста, после чего свободно использоваться под конкретные задачи.

В свою очередь, TF-IDF [75] (Term Frequency-Inverse Document Frequency) – это статистическая модель, которая так же, как и BERT, широко используется в анализе и обработке текстов. Основная задача данной модели заключается в том, чтобы определять, какие термины наиболее значимы для конкретного текста или набора текстов, учитывая при этом как локальную частоту термина в документе, так и глобальное распространение во всём наборе, что позволяет выделять ключевые слова, игнорируя общие и малоинформативные термины.

Этот подход позволяет значительно сократить время, необходимое для анализа и реагирования на новые угрозы, а также повысить точность классификации уязвимостей за счёт их группировки по смысловому сходству.

2) **Генерация мер противодействия для категорий уязвимостей** — после формирования семантически однородных категорий следующим шагом становится автоматическая разработка соответствующих мер защиты. На этом этапе создаётся база знаний, включающая типовые меры противодействия, применимые к каждой группе уязвимостей. Информация для формирования таких мер поступает из авторитетных открытых источников, включая NVD, рекомендации MITRE ATT&CK и другие. На основе анализа объединённых данных система автоматически подбирает и формирует соответствующие пакеты защитных мер для каждой категории уязвимостей.

3) **Категоризация уязвимостей по семантическому смыслу (обратная итерация)** — заключительный этап завершает цикл автоматизированной генерации мер противодействия. Он обеспечивает обратную связь для системы, позволяя

уточнять существующие категории и обновлять базу знаний в режиме реального времени. Это делает модель адаптивной к изменениям в киберугрозной среде и обеспечивает её устойчивость к новым видам атак.

Таким образом, три основных принципа обеспечивают комплексный подход к защите информационных систем. Они позволяют минимизировать временные затраты, повысить точность анализа и адаптироваться к новым угрозам, что особенно важно в условиях быстро развивающегося ландшафта киберугроз.

ЗАКЛЮЧЕНИЕ

В результате проведённого исследования были разработаны методологии автоматизированной генерации сценариев кибератак и мер противодействия на основе интеграции данных из графовой базы знаний. В современном мире киберугрозы становятся более многоступенчатыми и сложными. Злоумышленники в своих корыстных целях используют комбинации уязвимостей, техник и шаблонов атак. В таких условиях традиционные методы анализа угроз (например, ручной анализ данных из отдельных баз знаний) перестают быть эффективными. Поэтому работа по созданию адаптивной системы, способной противостоять быстро развивающимся кибератакам, остаётся актуальной и необходимой на сегодняшний день.

Одним из ключевых достижений выпускной квалификационной работы является агрегация данных из различных источников (CAPEC, MITRE ATT&CK, CWE, CVE, CISA KEV) в единую графовую модель. Во-первых, разобщённые данные часто приводят к неполному анализу угроз. Во-вторых, созданная модель позволяет выявлять сложные взаимосвязи между компонентами кибератаки (например, связь между техникой и шаблоном атаки). Следует отметить, что автоматизация данного топологического моделирования позволяет значительно сократить время на анализ данных и построение сценариев атак. Также очень часто причиной ошибок при ручном анализе сложных взаимосвязей между компонентами киберугроз становится человеческий фактор. Одно из главных преимуществ разработанной модели – её динамическое обновление, это гарантирует актуальность данных и позволяет своевременно реагировать на изменения в киберландшафте. Немаловажно, что автоматизация позволяет не только проводить анализ угроз, но и предлагать конкретные шаги для их нейтрализации в виде генерации пакетов мер защиты на основе выявленных угроз.

Новизна полученных результатов заключается в объединении методов теории графов, машинного обучения и анализа рисков для создания единой системы, способной работать в режиме реального времени. Разработанная методология

автоматической генерации сценариев атак и мер противодействия является первым шагом к созданию универсальной теоретической основы для анализа угроз и разработки мер защиты.

Впервые на практике была применена декомпозиция данных CVSS с использованием метода Шепли, что позволило справедливо распределить общий показатель риска между компонентами (конфиденциальность, доступность и целостность). Это, несомненно, повысило точность оценки рисков и минимизировало ошибки, связанные с недооценкой или переоценкой угроз.

Практическая ценность полученных результатов заключается в возможности внедрения разработанной модели в автоматизированные информационные системы для повышения их устойчивости к постоянно эволюционирующим угрозам. Модель позволяет автоматически строить сценарии атак на основе актуализируемых данных, что помогает своевременно выявлять потенциальные угрозы и минимизировать различного рода ошибки.

Автоматическая генерация сценариев освобождает специалистов от необходимости вручную анализировать большие объёмы данных, что, в свою очередь, повышает эффективность работы.

В рамках работы была разработана графовая модель и методология автоматизированной генерации сценариев атак и мер противодействия, представляющие собой универсальный и гибкий инструмент для анализа угроз. Особенно ценной в условиях быстрого развития киберугроз её делает то, что она сочетает в себе теоретическую проработанность и практическую применимость.

Результаты работы подтверждают актуальность и значимость предложенной методологии для современной кибербезопасности, а также открывают новые перспективы для дальнейшего совершенствования подходов к защите информационных активов. Таким образом, данная работа вносит существенный вклад в развитие методов анализа угроз и разработки мер защиты, что играет важную роль в обеспечении информационной безопасности в современном мире.

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред.

чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9 Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) Остапенко Г.А., Щербакова Д.В., Мирошниченко Т.Ю., Остапенко А.А.,

Кривошеин А.С. // Информация и безопасность. 2023 – Т. 26. № 3. – С. 329-340. – Текст: непосредственный.

10 Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) Остапенко Г.А., Щербакова Д.В., Мирошниченко Т.Ю., Остапенко А.А., Краснобородкин А.Г. // Информация и безопасность. 2023. – Т. 26. № 3. – С. 341358. – Текст: непосредственный.

11 Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) Остапенко Г.А., Щербакова Д.В., Мирошниченко Т.Ю., Остапенко А.А., Егоров А.Ю. // Информация и безопасность. 2023. – Т. 26. № 3. – С. 359-372. – Текст: непосредственный.

12 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 7-30. – Текст: непосредственный.

13 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 31-54. – Текст: непосредственный.

14 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 55-66. – Текст: непосредственный.

15 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 67-80. – Текст: непосредственный.

16 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 81-90. – Текст: непосредственный.

17 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 91-98. – Текст: непосредственный.

18 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М. Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 99-108. – Текст: непосредственный.

19 Овчинский А.С. Деструктивные информационные воздействия на аудиторию электронной образовательной среды / А.С. Овчинский, К.К. Борзунов // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 109-116. – Текст: непосредственный.

20 Минаев В.А. Геофизические угрозы кибербезопасности / В.А. Минаев, А.О. Фаддеев, А.В. Мокшанцев // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 117-124. – Текст: непосредственный.

21 Лавриненко М.М. Энергоинформационный обмен и технологии, основанные на новых физических принципах / М.М. Лавриненко, П.Ю. Филяк // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 125-134. – Текст: непосредственный.

22 Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М.

Голембиовский, К.Е. Шинаков // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 135-142. – Текст: непосредственный.

23 Александров А.Г. Анализ угроз информационной безопасности при использовании облачных сервисов / А.Г. Александров, А.Ю. Петухов, М.Ю. Рытов // Информация и безопасность. 2024. – Т. 27. Вып. 1. – С. 143-151. – Текст: непосредственный.

24 Овчинский А.С. Информационное противоборство с деструктивными сетевыми сообществами / А.С. Овчинский, К.К. Борзунов // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 159-168. – Текст: непосредственный.

25 Минаев В.А. Программно-алгоритмический комплекс поиска деструктивной информации в системах мгновенного обмена сообщениями / В.А. Минаев, А.В. Симонов // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 169-176. – Текст: непосредственный.

26 Минаев В.А. Кибербезопасность и киберустойчивость беспилотных транспортных систем / В.А. Минаев, А.С. Толпыгин // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 177-184. – Текст: непосредственный.

27 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло, А.С. Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 185-196. – Текст: непосредственный.

28 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 197-208. – Текст: непосредственный.

29 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть III) / Д.В. Щербакова, А.Ю.

Пекло, Ю.В. Макаров, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 209-218. – Текст: непосредственный.

30 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков, Д.С. Покудин, А.А. Ноздрюхин // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 219-230. – Текст: непосредственный.

31 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 231-238. – Текст: непосредственный.

32 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 239-246. – Текст: непосредственный.

33 Бабурин А.В. Способ защиты информации о форме и координатах объекта от лазерных 3D сканеров / А.В. Бабурин, Л.А. Глущенко, К.А. Иванов // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 247-256. – Текст: непосредственный.

34 Сердечный А.Л. Информационное картографирование Blockchain-транзакций киберпреступников в экосистеме TON / А.Л. Сердечный, А.О. Абрамов, Е.А. Москалева // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 257-272. – Текст: непосредственный.

35 Смирнов В.В. Кибератаки вида «анализ целевого объекта»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин //

Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 273-284. – Текст: непосредственный.

36 Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. – Т. 27. Вып. 2. – С. 285-294. – Текст: непосредственный.

37 Минаев В.А. Цифровая платформа для защищенных информационно управляющих систем беспилотного транспорта / В.А. Минаев, А.С. Толпыгин // Информация и безопасность. 2024. – Т. 27. Вып. 3. – С. 309-318. – Текст: непосредственный.

38 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. – Т. 27. Вып. 3. – С. 319-336. – Текст: непосредственный.

39 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. – Т. 27. Вып. 3. – С. 337-378. – Текст: непосредственный.

40 Киберугрозы в России и СНГ. Аналитика и прогнозы. – URL: https://www.f6.ru/docs/report/f6-cybercrime-trends-annual-report-2024-2025.pdf – Текст: электронный.

41 Тренды рынка кибербезопасности в России: прогноз на 2024-2025 гг. – URL: https://www.anti-malware.ru/analytics/Technology_Analysis/Cybersecurity-market-trends-2024-2025#part33. – Текст: электронный.

42 NVD. – URL: https://nvd.nist.gov/. – Текст: электронный.

43 NVD на грани краха: NIST отчаянно ищет спасение. – URL: https://www.securitylab.ru/news/548757.php?ysclid=mb0g5ewyk1582357273. – Текст: электронный.

44 CVE. – URL: https://cve.mitre.org/. – Текст: электронный.

45 CWE. – URL: https://cwe.mitre.org/index.html – Текст: электронный.

46 MITRE ATT&CK. – URL: https://attack.mitre.org/. – Текст: электронный.

47 Матрица MITRE ATT&CK. – URL: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

48 CAPEC. – URL: https://capec.mitre.org/. – Текст: электронный.

49 Каталог KEV | CISA. – URL: https://www.cisa.gov/resources-tools/resources/kev-catalog. – Текст: электронный.

50 Exploit Prediction Scoring System (EPSS). – URL: https://www.first.org/epss/. – Текст: электронный.

51 Общая система оценки уязвимостей (CVSS). – URL: https://www.first.org/cvss/specification-document. – Текст: электронный.

52 CVSS v3.1 Specification Document. – URL: https://www.first.org/cvss/v3-1/specification-document. – Текст: электронный.

53 Автоматизированный атлас кибератак / Г.А. Остапенко, А.П. Васильченко, А.О. Калашников, А.А. Остапенко; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – с. 7-53. (Серия «Теория сетевых войн»; вып. 9). – Текст: непосредственный.

54 The KEV Catalog | CISA. – URL: https://www.cisa.gov/resources-tools/resources/kev-catalog. – Текст: электронный.

55 CISA KEV Cybersecurity Division. – URL: https://www.cisa.gov/about/divisions-offices/cybersecurity-division. – Текст: электронный.

56 А.А. Остапенко. Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А.А. Остапенко, В.П. Шелякин, Е.С. Короткова, А.С. Кривошеин, Д.А. Мальцева, П.А. Меркулов, Н.Д. Никитин, М.О. Титаренко // Информация и безопасность. 2024. – Т.27. Вып.4. С.24-48. – Текст: непосредственный.

57 CVSS 4.0: аналитический обзор новой версии популярного стандарта. – URL: https://habr.com/ru/companies/pt/articles/788310/. – Текст: электронный.

58 The EPSS Model. – URL: https://www.first.org/epss/model. – Текст: электронный.

59 The EPSS User Guide. – URL: https://www.first.org/epss/user-guide. – Текст: электронный.

60 EPSS SecurityLab.ru by Positive Technologies. – URL: https://www.securitylab.ru/glossary/epss/?ysclid=maxlo2zhzk486810444. – Текст: электронный.

61 Knowledge Graphs in Cybersecurity: A Systematic Review / Knowledge andInformation Systems (2023) 65:3511–3531. – Текст: непосредственный.

62 Elmar Kiesling . The SEPSES Knowledge Graph: An Integrated Resource for Cybersecurity / Elmar Kiesling, Andreas Ekelhart, Kabul Kurniawan and Fajar Ekaputra // Vienna, Austria, 2019. – Текст: непосредственный.

63 Jonathan L. Gross. Graph Theory and Its Applications, Third Edition / Jonathan L. Gross, Jay Yellen, Mark Anderson. 2019. // С.45. – Текст: непосредственный.

64 И.А. Какорин. Основные принципы информационной безопасности / И.А. Какорин // International Journal of Humanities and Natural Sciences. 2023. – Vol. 2-2 (77). – Текст: непосредственный.

65 Алгоритм Гэйла-Шепли – Википедия. – URL: https://ru.wikipedia.org/wiki/%D0%90%D0%BB%D0%B3%D0%BE%D1%80%D0%B8%D1%82%D0%BC_%D0%93%D1%8D%D0%B9%D0%BB%D0%B0_%E2%80%94_%D0%A8%D0%B5%D0%BF%D0%BB%D0%B8. – Текст: электронный.

66 Applied Graph Theory in Computer Security" R. C. Read, D. H. Smith, 2018. Глава 3 «NETWORK AND GRAPH THEORY» (Сетевая и графовая теория). – Текст: непосредственный.

67 Остапенко А.Г. Автоматизированный поиск соответствия уязвимостей, шаблонов и техник кибератак / А.Г. Остапенко, Ю.В. Макаров, Д.А. Нархов, А.Е. Нетребин, Н.А. Исаев, Д.Р. Зинченко, Д.И.Чаусов // Информация и безопасность. 2025. – Т.28. Вып.1. С.24. – Текст: непосредственный.

68 Управление рисками Документация SECURITM. – URL: https://service.securitm.ru/help/risks?ysclid=mcg85czmb9340409000. – Текст: электронный.

69 Алгоритм Гэйла – Шепли. – URL: https://ru.wikipedia.org/wiki/%D0%90%D0%BB%D0%B3%D0%BE%D1%80%D0%B8%D1%82%D0%BC_%D0%93%D1%8D%D0%B9%D0%BB%D0%B0_%E2%80%94_%D0%A8%D0%B5%D0%BF%D0%BB%D0%B8. – Текст: электронный.

70 Методика оценки уровня критичности уязвимостей. – URL: https://www.garant.ru/products/ipo/prime/doc/405504555/. – Текст: электронный.

71 Отраднов К.К. Преимущества использования графовых баз данных при разработке прикладных приложений / К.К. Отраднов, А.С. Алёшкин, В.Н. Калинин // Вестник РГРТУ. 2023. – №86, С.73-80. – Текст: непосредственный.

72 Когнитивное моделирование вектора кибератак на основе меташаблонов CAPEC. – URL: https://cyberrus.info/wp-content/uploads/2021/03/2-16-242-21_1.-Vasilyev.pdf. – Текст: электронный.

73 ГОСТ Р 59709-2022. Защита информации. Управление компьютерными инцидентами. Термины и определения. – URL: https://regulhub.kaspersky.ru/upload/iblock/937/0i8uuoendy5tb29btcn9qjnf7cttkgvu.pdf. – Текст: электронный.

74 Модели BERT для машинного обучения. – URL: https://habr.com/ru/companies/skillfactory/articles/862130/. – Текст: электронный.

75 Извлечение признаков из текстовых данных с использованием TF-IDF. – URL: https://habr.com/ru/companies/otus/articles/755772/. – Текст: электронный.

76 Markusbayer / CySecBERT. – URL: https://huggingface.co/markusbayer/CySecBERT. – Текст: электронный.

77 ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. – URL: https://ksc-alternativa.com.ru/wp-content/uploads/2019/08/%D0%93%D0%9E%D0%A1%D0%A2-%D0%A0-50922-2006.pdf. – Текст: электронный.

78 Графовая база данных – Википедия. – URL: https://ru.wikipedia.org/wiki/%D0%93%D1%80%D0%B0%D1%84%D0%BE%D0%B2%D0%B0%D1%8F_%D0%B1%D0%B0%D0%B7%D0%B0_%D0%B4%D0%B0%D0%BD%D0%BD%D1%8B%D1%85. – Текст: электронный.

ПРИЛОЖЕНИЕ А

Таблица 1 - Взаимосвязи между тактиками Mitre Attack

Текущая тактика	Следующая тактика	Описание
СТАРТ	Разведка	Атакующий начинает с разведки
	Первоначальный доступ	Атакующий сразу пытается получить доступ к системе, предполагая наличие минимальной информации о цели
	Выполнение	Атакующий запускает вредоносный код на целевой системе без явного этапа получения доступа
	Получение учетных данных	Атакующий начинает с попыток добычи учетных данных, предполагая, что у него есть базовая информация о структуре системы или пользователях
Разведка	Подготовка ресурсов	На основе собранной информации атакующий готовит необходимую инфраструктуру
	Первоначальный доступ	Атакующий использует собранную информацию первоначального доступа
	СТОП	Атакующий завершил разведку
Подготовка ресурсов	Первоначальный доступ	Подготовленная инфраструктура используется для реализации начального доступа к целевой системе
	СТОП	Подготовка ресурсов завершена, но атакующий сменил цель

Продолжение таблицы 1

Первоначальный доступ	Выполнение	После получения доступа атакующий запускает вредоносный код
	Закрепление	Атакующий закрепляется в системе сразу после получения доступа
	СТОП	После получения доступа атака остановлена
Выполнение	Повышение привилегий	После запуска вредоносного кода атакующий пытается повысить свои привилегии для расширения возможностей внутри системы
	Предотвращение обнаружения	Запущенный код модифицируется или маскируется для обхода систем безопасности
	СТОП	Вредоносный код выполнен, атака достигла цели
Закрепление	Повышение привилегий	Используя механизмы закрепления, атакующий пытается получить более высокие привилегии
	Предотвращение обнаружения	Механизмы закрепления адаптируются для скрытия от антивирусов и систем обнаружения вторжений
	Обнаружение	После закрепления атакующий начинает исследование системы, чтобы найти дополнительные возможности для перемещения или добычи данных
	СТОП	После закрепления в системе атака остановлена, так как атакующий сменил цель

Продолжение таблицы 1

Повышение привилегий	Перемещение внутри периметра	С повышенными правами атакующий получает возможность перемещаться по внутренней сети
	Получение учетных данных	Высокие привилегии позволяют атакующему добраться до защищённых хранилищ учетных данных
	Предотвращение обнаружения	Атакующий использует свои полномочия для отключения систем мониторинга, изменения журналов событий или установки доверенных модулей
	СТОП	Привилегии повышены, операция временно прекращена до подходящего момента
Предотвращение обнаружения	Закрепление	Для обеспечения долгосрочного доступа атакующий использует скрытые или легитимные методы закрепления, чтобы избежать обнаружения
	Повышение привилегий	Атакующий использует обход защиты для выполнения действий, направленных на повышение привилегий
	Обнаружение	Атакующий продолжает исследование системы, используя техники, которые трудно обнаружить
	СТОП	Техники уклонения успешно применены, атака остановлена

Продолжение таблицы 1

Обнаружение	Получение учетных данных	Во время исследования атакующий находит места хранения учетных данных
	Перемещение внутри периметра	Полученная информация о системе, пользователях и сетевых соединениях позволяет атакующему двигаться дальше по инфраструктуре
	Сбор данных	Атакующий начинает собирать данные, найденные во время исследования
	СТОП	Исследование системы завершено, операция остановлена, для продажи данных
Получение учетных данных	Перемещение внутри периметра	Полученные учетные данные используются для доступа к другим системам или сервисам в рамках внутренней сети
	Сбор данных	Учетные данные собираются и сохраняются для дальнейшего использования или передачи
	СТОП	Добыча учетных данных завершена, атака остановлена для продажи данных

Продолжение таблицы 1

Перемещение внутри периметра	Обнаружение	При перемещении по сети атакующий исследует новые системы, службы и пользовательские данные
	Сбор данных	Атакующий собирает данные с новых систем, к которым получил доступ после перемещения
	Предотвращение обнаружения	Атакующий использует скрытные способы перемещения, чтобы избежать обнаружения
	СТОП	Перемещение по сети завершено
Сбор данных	Организация управления	Собранные данные отправляются на удалённый сервер управления (C2)
	Перемещение внутри периметра	Собранные данные используются для планирования следующих этапов перемещения по сети
	СТОП	Сбор данных завершён, атака остановлена для реализации данных
Организация управления	Эксфильтрация данных	Через канал управления (C2) атакующий начинает извлечение данных из сети
	Предотвращение обнаружения	Атакующий использует сложные или легитимные C2-каналы, чтобы избежать блокировки или обнаружения
	СТОП	Канал управления временно не используется, атака остановлена

Заключение таблицы 1

Эксфильтрация данных	Деструктивное воздействие	После извлечения данных атакующий наносит ущерб: шифрует данные, изменяет их или полностью удаляет для максимального деструктивного воздействия
	Организация управления	Атакующий продолжает использовать C2-канал для контроля над системой и координации дальнейших действий
	Сбор данных	Продолжается сбор данных для дальнейшего извлечения или анализа
	Перемещение внутри периметра	Атакующий перемещается по сети, чтобы найти дополнительные данные для извлечения
	СТОП	Извлечение данных завершено, атака остановлена
Деструктивное воздействие	Обнаружение	После нанесения ущерба атакующий снова исследует систему, чтобы понять, какие данные были затронуты или какие последствия вызвало воздействие
	Сбор данных	Атакующий собирает информацию о результате воздействия
	Предотвращение обнаружения	Атакующий маскирует последствия воздействия, чтобы избежать обнаружения или восстановления системы
Деструктивное воздействие	Закрепление	После воздействия атакующий оставляет точки закрепления для повторного доступа, если система будет восстановлена
	СТОП	Атака завершена после ненанесения ущерба
СТОП	-	Конечная точка атаки

ПРИЛОЖЕНИЕ Б

ГЛОССАРИЙ

В данной выпускной квалификационной работе используются термины, которые определены с помощью источника [73,77,78]:

Информационная безопасность – защищённость автоматизированных систем и их компонентов от нежелательных с точки зрения использующих их субъектов воздействий.

Защита информации – деятельность, направленная на предотвращение утечки защищаемой информации, несанкционированных и непреднамеренных воздействий на защищаемую информацию.

Техническая защита информации – защита информации, заключающаяся в обеспечении некриптографическими методами безопасности информации (данных), подлежащей (подлежащих) защите в соответствии с действующим законодательством, с применением технических, программных и программно-технических средств.

Безопасность информации (данных) – состояние защищённости информации (данных), при котором обеспечены её (их) конфиденциальность, доступность и целостность.

Угроза (безопасности информации) – совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации.

Уязвимость (информационной системы) – свойство информационной системы, обусловливающее возможность реализации угроз безопасности обрабатываемой в ней информации.

Модель угроз (безопасности информации) – физическое, математическое, описательное представление свойств или характеристик угроз безопасности информации.

Мониторинг безопасности информации – постоянное наблюдение за процессом обеспечения безопасности информации в информационной системе с целью установить его соответствие требованиям безопасности информации.

Анализ информационного риска – систематическое использование информации для выявления угроз безопасности информации, уязвимостей информационной системы и количественной оценки вероятностей реализации угроз с использованием уязвимостей и последствий реализации угроз для информации и информационной системы, предназначенной для обработки этой информации.

Оценка информационного риска – общий процесс анализа информационного риска и его оценивания.

Требование по защите информации – установленное правило или норма, которая должна быть выполнена при организации и осуществлении защиты информации, или допустимое значение показателя эффективности защиты информации.

Средство защиты информации – техническое, программное, программно-техническое средство, вещество и (или) материал, предназначенные или используемые для защиты информации.

Средства государственной системы обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы РФ – технические, программные, программно-аппаратные и иные средства для обнаружения компьютерных атак, технические, программные, программно-аппаратные и иные средства для ликвидации последствий компьютерных атак, технические, программные, программно-аппаратные и иные средства поиска признаков компьютерных атак в сетях электросвязи, технические, программные, программно-аппаратные и иные средства обмена информацией, для которых имеется документальное подтверждение соответствия требованиям, установленным в нормативных правовых актах и методических документах ФСБ России.

Информационные ресурсы – информационные системы, информационно-телекоммуникационные сети и автоматизированные системы управления.

Компьютерная атака – целенаправленное воздействие программных и (или) программно-аппаратных средств на информационный ресурс в целях нарушения и (или) прекращения его функционирования и (или) создания угрозы безопасности обрабатываемой таким ресурсом информации.

Тактика (проведения компьютерной атаки) – совокупность приёмов и способов действий, используемых для проведения компьютерной атаки.

Техника (проведения компьютерной атаки) – совокупность и порядок действий, используемых для проведения компьютерной атаки в рамках соответствующих тактик.

Обнаружение компьютерных атак – комплекс мероприятий по выявлению и анализу признаков компьютерных атак и определению их типа.

Реагирование на компьютерный инцидент – последовательное выполнение этапов реагирования на компьютерный инцидент с целью установления технических причин и условий возникновения компьютерного инцидента и ликвидации его последствий.

Ликвидация последствий компьютерного инцидента – совокупность действий, направленных на восстановление штатного режима функционирования информационных ресурсов после компьютерного инцидента и удаление изменений, внесённых нарушителем ИБ в информационный ресурс.

Принятие мер по предотвращению повторного возникновения компьютерных инцидентов – реализация мер защиты информации, обеспечивающих противодействие (снижение вероятности вплоть до недопущения) повторному возникновению компьютерных инцидентов.

Графовая база данных – разновидность баз данных с реализацией сетевой модели в виде графа и его обобщений.

Риск – это вероятность наступления ущерба определённой величины, то есть вероятный ущерб, который зависит от защищённости системы.